


# INDIVIDUAL ASSIGNMENT

# CT114-3-3-VCS

# ADVANCED CYBER SECURITY

| | |
|---|---|
| **NAME** | **Shady Ehab Assad Ibrahim** |
| **TP NUMBER:** | **TP073549** |
| **INTAKE CODE:** | **APD3F2505CS(CYB)** |
| **MODULE TITLE:** | **Advanced Cyber Security** |
| **MODULE LECTURER:** | **Mohd Norfahmi Bin Jaafar** |
| **CASE STUDY TITLE:** | **Suffolk County - BlackCat** |
| **HANDOUT DATE:** | **22/10/2025** |
| **HAND IN DATE**: | **23/1/2026** |

# Table of Contents


1. Introduction ..... 3
2. Overview of the Case Study ..... 3
3. Timeline of the Attack ..... 3
4. Summary of Events/Attacks ..... 4
5. Threat Targets and Impacts ..... 4
5.1 Threat Targets ..... 4
5.2 Potential Impacts ..... 5
5.3 Summary ..... 6
6. Cybercrime Profiling ..... 6
6.1 Background ..... 6
6.2 Motivation and Objectives ..... 7
6.3 Behavioural Characteristics ..... 8
6.4 Attack Strategy and Methods ..... 8
7. Tactics, Techniques, and Procedures (TTP) ..... 10
7.1 Initial Access Vector ..... 10
7.2 Privilege Escalation and Lateral Movement ..... 10
7.3 Data Exfiltration and Payload Deployment ..... 11
7.4 Mapping to the MITRE ATT&CK Framework with Case ..... 11
8. Conclusion of Section A ..... 12
9. Breach and Attack Simulation Plan ..... 12
10. Reconnaissance ..... 12
11. Initial Access ..... 19
12. Execution ..... 22
13. Impacts ..... 24
14. Detection Action Plan ..... 25
15. Forensics Analysis (PCAP + EVTX Triage Findings) ..... 30
16. Detection Limitations ..... 30
17. Incident Response Plan, Cyber Playbook, and Prevention Action Plan ..... 31
18. Incident Response Plan ..... 31
19. Cyber Playbook ..... 40
20. Prevention Action Plan ..... 42
21. Conclusion of Section B ..... 45
22. References ..... 46

# 1. Introduction

In this report, a significant ransomware attack on Suffolk County, has been analysed with respect to attacker behaviour and implications to defence. Results are confirmed by control simulation and evidence matching which prove behavioural similarity as opposed to exploit imitation.

# 2. Overview of the Case Study

In September 2022, Suffolk County, New York was hit with one of the most extensive ransomware attacks against a U.S. local government. The attack brought county systems to their knees, stopped critical services and laid bare vast deficiencies in infrastructure, governance and incident response for cybersecurity. The ransomware strike was launched by a skilled cybercriminal hacking syndicate identified as BlackCat/ALPHV, and it has been linked to many lateral movement attacks against both public and private entities. (Nir, 2022, Jones, 2024) The attack did not happen in a isolation; it came after months of undetected network penetration and ignored alerts from law enforcement and security vendors. The extent of the breach launched investigations, then later led to questions about the county's readiness and risk management with technology.

Suffolk County was in a state of fragmented leadership when it came to IT with no centralized cybersecurity authority Chief Information Security Officer (CISO), and its many IT teams working in silos. Key systems such as perimeter firewall protections and malware defences were outdated or not configured correctly, enabling attackers to leverage weaknesses without setting off an alarm. These broader problems paved the way for an extended and damaging breach that remained unnoticed for weeks leading to operational disarray on a large scale.

# 3. Timeline of the Attack

The ransomware event was a multi-month process whose intrusion strategy was multi-phase, as opposed to a direct compromise:

**Late 2021:** The first breach is assumed to have happened due to the usage of the Apache Log4j vulnerability CVE-2021-44228 in one of their public systems that had not been updated, which allowed unauthenticated execution of remote code.

**Early to Mid-2022:** After having made the initial access, subsequent attackers engaged in lateral movement, privilege escalation, and collection of credentials and persisted. The activities were not noticed because of the lack of monitoring and disjointed security control.

**June 2022:** Federal authorities were making threats about bizarre traffic over networks and risks of malwares. Such alerts were not transformed into appropriate remediation or containment measures in time so that attacker activity could proceed.

**September 8, 2022:** The execution of ransomware became visible by encrypted files and system disruption, which forced the closure of essential services, such as email systems and the demand to close the public websites to reduce the spread.

**September to December 2022:** Months of recovery efforts followed as the county worked to repair its services and determine the extent of the incident. And services like online bill paying, access to court records and operations in emergencies continued to be out of commission for days.

# 4. Summary of Events/Attacks

The Suffolk County ransomware incident is a clear demonstration that contemporary cyber-attacks typically take advantage of technical weaknesses as well as administrative failures. Through an exploited known yet unpatched software vulnerability, the attackers infiltrated undetected, thanks to subpar monitoring and disjointed IT governance. The FBI and security vendors have been repeatedly warning about it, but the warnings weren't heeded with a sense of urgency that has to his arrival determined more time for the attackers to grow their base before pulling this final trigger.

The attackers caused serious operational and financial harm by encrypting files, disrupting services, and exfiltrating sensitive information. The systems in the counties were still operating only partially months later, and the price tag to recover, which included rebuilding of systems as well as forensic audits and improved cybersecurity, was expected to eclipse tens of millions of dollars. This incident highlights the need for vigilance in identifying and stopping threats early on, for a centralized cyber leadership, and for quickly responding to outside alerts.

# 5. Threat Targets and Impacts

## 5.1 Threat Targets

Key Suffolk County Ransomware Attack Targets The main targets of the Suffolk County ransomware attack were its critical information infrastructure, which sustained some vital public services and administrative activities. The attackers targeted computers in the Suffolk County Clerk’s Office domain that contained court records, legal papers, financial information, and personal data about county residents and employees. The systems were lucrative targets

because of the sensitivity of the data and institutional significance to everyday government functions (Nir, 2022).

Aside from systems with data, the attackers also went after Networking and Authentication infrastructure which then allows them to gain more rights and spread once they're inside on two or more environments. Lack of centralized cyber security governance and uneven enforcement of access controls permitted adversaries to leverage trust relationships among systems. This facilitated wider penetration from that originally compromised access point and expanded the volume of, and harm caused by the attack (Jones, 2024).

Indirect impact was also felt at public facing digital services. The county's websites, email system, online payment network and internal business tools were shut down in a bid to protect them after ransomware was found on the network. While these services were not the primary target, this damage had a large amplification on the overall impact of the attack. In penetrating the heart of backend systems, attackers effectively crippled internal operations and public service delivery both.

## 5.2 Potential Impacts

The attack had the potential to influence opinions on operational, financial, public image and data safety aspects. Suffolk County was driven by the ransomware attack to close down a larger proportion of its IT infrastructure, and as a result brought an end to many basic services. Processes that depended upon important functions such as courts operations, emergency call handling and online citizen services ran late or reverted to manual procedures temporarily both of which had the same undesirable consequence for efficiency and error rates in output (Nir, 2022).

From an economic standpoint, the attack incurred enormous costs on system recovery and forensics, legal consultation fees and upgrades in cyber security infrastructure. Recovery and remediation expenses were estimated at more than $25 million, though this exclusion did not account for long-term investment necessary to resolve governance and security deficiencies (Jones, 2024). The ransomware attack added a particularly severe burden to public finances and highlighted the economic consequences of cybersecurity capability lag.

There was also a substantial data security and privacy risk from the attack. The expose of personal information meant that residents and employees were at continuous peril from identity theft, fraudulence swindles and sustained maltreatment of their vital data. Such breaks in

security undermine public faith in government institutions and bring strong doubts on compliance with regulations for protecting one's data safely, and ethic requirements.

Reputation damage was yet another key result. Long-lasting service outages, public disclosure of dismissed warnings and political leadership errors of judgment all damaged confidence in the county authorities' ability to guard digital assets. This loss of public trust can have long-term effects on popular engagement and confidence in digital government services, especially when people depend even more heavily now upon online platforms for essential public transactions.

## 5.3 Summary

Overall, the ransomware attack of Suffolk County targeted essential local government management systems, data stores and network services connected to the data stores, which led to a long-term system outage and expensive recovery fees. The attackers have used a set of technical exposure and organisational vulnerabilities, namely, lapses in access control, monitoring coverage, and fragmented governance, which jointly increased the magnitude and the duration of the impact. Availability was the worst hit feature of the CIA triad since any type of service outages directly interfered with the necessary public services and continuity of operations. The additional pressure due to confidentiality concerns is the possibility of exposing data whereas integrity issues affected the trust in the reliability of the system and the government records. In general, the example shows that the effects of ransomware are too costly to disregard as diary and technical damages, but it is also clear that it creates a financial burden, erosion of trust, and loss of institutional credibility (Jones, 2024; Nir, 2022).

# 6. Cybercrime Profiling

## 6.1 Background

The Suffolk County ransomware attack is discussed because of the activity of ALPHV, or the BlackCat group, a highly organized ransomware-as-a-service (RaaS) organization that appeared at the end of 2021. In contrast to loosely coordinated cybercriminal gangs, ALPHV is a co-ordinated criminal, as they merge central leadership with a distributed affiliate structure to run intrusions and spread ransomware on a massive scale (Trend Micro, 2022; Phipps and Nurse, 2025). Technically significant features of ALPHV are custom ransomware tooling and professional infrastructure to operate extortion, such as affiliate recruitment, revenue-sharing, and data-leak sites, to aid in dual- extortion tactics. The group often attacks public-sector organisations, including local governments, where reliance on digital services frequently is

high and the frustration of (prolonged) disruptions is low, which escalates the risks of a successful extortion and operational interference.

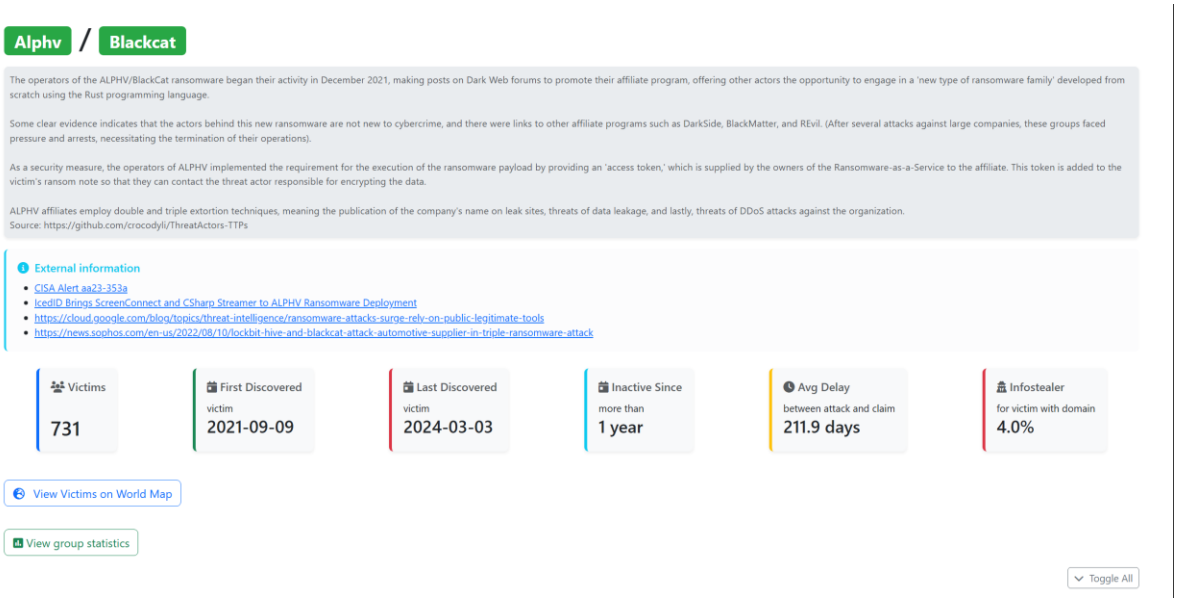



*Figure 1: ALPHV (BlackCat) Ransomware Group Profile and Operational Statistics (Julien Mousqueton, 2021)*

## 6.2 Motivation and Objectives

The primary motivation driving ALPHV (BlackCat) operations is financial extortion, rather than indiscriminate disruption or ideological interference. This is evidenced by the group's consistent use of double-extortion ransomware tactics as it is a combination of system encryption and sensitive information exfiltration. This method adds to coercive pressure on victims because even having reservations does not exclude the possibility of them releasing their data to the public or within the frames of regulation and legal fines (CISA, 2024; BlackCat Ransomware Attacks Not Merely a Byproduct of Bad Luck, 2022).

The secondary kind of motivation is reputational and strategic positioning in the Ransomware-as-a-Service (RaaS) ecosystem. Public-sector organisations targeted by high-profile attacks are a statement of competency and increase the attractiveness and plausibility of ALPHV to affiliates and partners. Efficient operations are consequently the primary source of revenue in addition to signalling to maintain relevance and recruitment in the background of underground cybercriminal markets (Phipps and Nurse, 2025).

The Suffolk County episode indicates that it is a cost-benefit strategy rather than a short-term disruption. Extended dwell time, lateral movement, and persistence are signs that there was a calculated effort to leverage as much as possible by taking advantage of IT technical

vulnerabilities and organisational failure, such as fragmented IT governance and delayed patch management. The conditions probably had the effect of decreasing the detection probability and enhancing monetisation potential. There is no evidence of ideological, hacktivist, or espionage-driven intent; instead, the incident aligns with ALPHV's established model in which financial extortion is prioritised, and psychological pressure is amplified through the threat of controlled data disclosure.

## 6.3 Behavioural Characteristics

Instead of being focused on the opportunistic approach, the ALPHV has the traits of a labelled structured and long-standing criminal organization. The group is characterized by the focus on stealth, long dwell time, and sequential plan of operations. Rather than installing ransomware as soon as access is obtained, ALPHV affiliates will postponing carry out internal reconnaissance, locate valuable contents, and weaken-defence controls before starting the next step of the extortion process. This strategy places speed last within its emphasis on operations success and ransom maximisation, a trend that the Suffolk County incident manifested (Trend Micro, 2022).

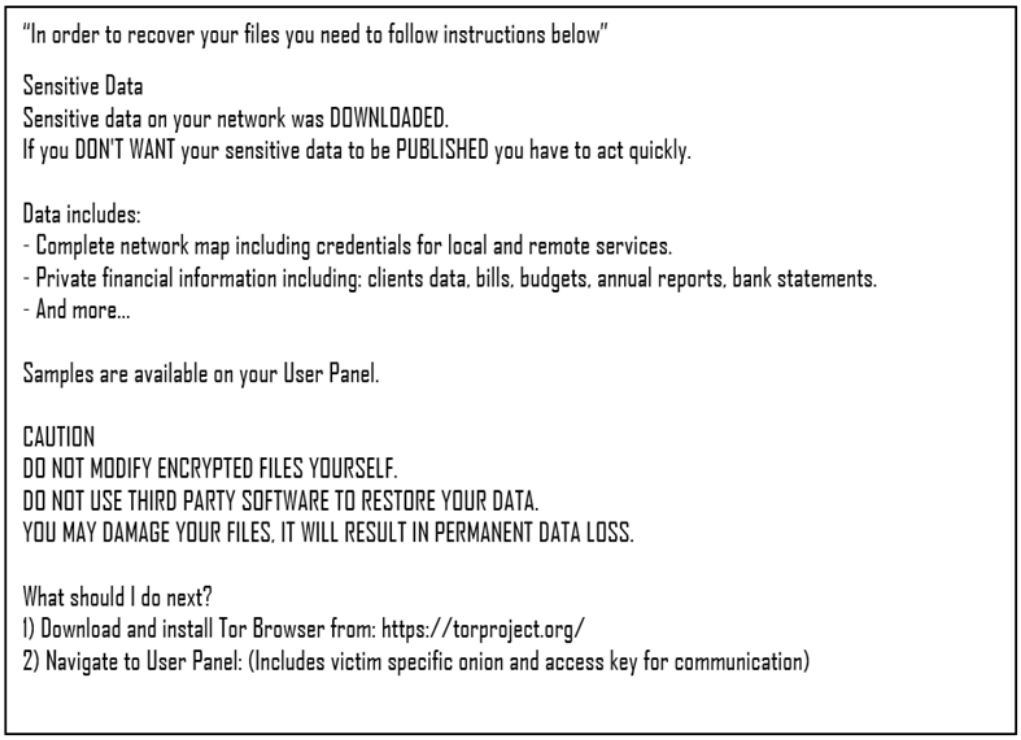
Most importantly, the process of ALPHV does not take indiscriminate or permanently destructive measures that will weaken the lever of extortion. Such fact of restraint confirms the conclusion that the actions of the group are controlled by economic motives, and it is not alleged that it has ideological, political, or hacktivist motives. Simultaneously, ALPHV exhibits a strong risk-taking and high-impact capacity, which is evidenced by a long dwell time, deliberate lateral movement, and tendency to disrupt critical services in the public sector to maximise coercive pressure. At the Suffolk County case, the local government adopted a low tolerance to outage and sluggish remedial capacity was further increased by the fact that the local government accepted this tolerance to an operational exposure degree and magnitude of impact.

Overall, this type of behaviour indicates a high-impact but controlled (moderate) risk appetite: the attackers were careful and slow (low-noise, stealth-first, long dwell time) but dangerous in terms of impact because of the ultimate deployment of the ransomware in order to maximise the leverages on extortion.

## 6.4 Attack Strategy and Methods

ALPHV's attack approach is guided by a multistage infiltration model that closely parallels well-established ransomware TTPs. Initial access usually comes through patch-free gaps at the

holes in software, stolen passwords or exposed services, an example being the Log4j vulnerability (#StopRansomware: ALPHV Blackcat | CISA, 2024) that took advantage of in the Suffolk County case. Once inside, attackers will work to ensure continuity of command and scale their influence over time. Subsequent phases of attack involve moving laterally across network segments. These focus on domain controllers, file servers and backup facilities to maximize impact. Data is exfiltrated before being encrypted. This allows extortion practices in which the public is threatened with leakages of personal information (Breaking down the BlackCat Ransomware Operation, 2022). In the final phase of implementation, all cryptocurrency-ransomware execution is synchronized across many machines to overwhelm any responses by security teams and speed operational disruption onward. Altogether, ALPHV's methodologies serve as a purposeful, well-resourced and adaptable approach to cyber extortion. This underscores the need for unilateral efforts on the part of modern organizational environments to not only defend themselves but to govern, administer and react.


"In order to recover your files you need to follow instructions below"

Sensitive Data
Sensitive data on your network was DOWNLOADED.
If you DON'T WANT your sensitive data to be PUBLISHED you have to act quickly.

Data includes:
- Complete network map including credentials for local and remote services.
- Private financial information including: clients data, bills, budgets, annual reports, bank statements.
- And more...

Samples are available on your User Panel.

CAUTION
DO NOT MODIFY ENCRYPTED FILES YOURSELF.
DO NOT USE THIRD PARTY SOFTWARE TO RESTORE YOUR DATA.
YOU MAY DAMAGE YOUR FILES, IT WILL RESULT IN PERMANENT DATA LOSS.

What should I do next?
1) Download and install Tor Browser from: https://torproject.org/
2) Navigate to User Panel: (Includes victim specific onion and access key for communication)

*Figure 2:ALPHV (BlackCat) Ransom Note Demonstrating Double-Extortion Tactics (Breaking down the BlackCat Ransomware Operation, 2022)*

# 7. Tactics, Techniques, and Procedures (TTP)

## 7.1 Initial Access Vector

The Suffolk County ransomware incident demonstrates an initial access technique consistent with known ALPHV (BlackCat) operations. Public analysis reports that attackers leveraged an important Apache Log4j remote code execution vulnerability (CVE- 2021-44228), which remained unpatched at the time of compromise. This vulnerability enabled unauthenticated remote code execution, allowing attackers to execute commands without valid credentials.

On the adversary side, those exposed services which are exposed to the attack of Log4j are a highly effective point of entry because of being very scalable, low cost of interaction and being able to circumvent perimeter authentication. Nonetheless, the technical vulnerability was not the only reason behind the success of this first access vehicle. Late patch release, ineffective IT governance and inability to operationalise external warning signals had a great impact on defensive preparedness and prolonged attacker dwell time. Public alerts and federal advisories on active use of the Log4j exploitation were not put into instant mitigation, and the vulnerable service was available during a significant vulnerability period.

This is a combination of technical exposure and organisational inertia, which fits the MITRE ATT&CK Initial Access tactic (TA0001), in which exploitation of applications facing the public allows low-noise compromise. It is also indicative of known ALPHV operational behaviour, where the attackers will focus on environments where the patch cycles are slow and security ownership is decentralised. Accordingly, initial access phase in the Suffolk County case does not only demonstrate attacker capability, but also systemic defensive failures which allowed a high-impact compromise.

## 7.2 Privilege Escalation and Lateral Movement

Following initial access, the attackers upgraded privileges and lateralized within the environment after gaining access to obtain greater control and access high-value systems. This phase was enabled by weak access controls, inconsistent least-privilege enforcement, and fragmented identity governance, so that compromised credentials were reused by an interconnected system. Consequently, the attackers could get their hands on such important assets like file servers and domain controllers, significantly increasing their ability to disrupt operations.

These activities align with the MITRE ATT&CK Privilege Escalation (TA0004) and Lateral Movement (TA0008) tactics, including techniques such as Credential Dumping (T1003) and

abuse of Remote Services (T1021).These methods are usually linked to BlackCat (S1068) activities, and in which the exploitation of credentials and exploitation of trust is conducted to expand the access of attackers to enterprise environments. The long dwell time in this step is an indication that authentication monitoring and endpoint visibility is therefore inadequate, which would limit observation of other abnormal access behaviours. This loss of time resulted in the attackers also having time to hold the final environment preparations of deploying a ransomware and demonstrates how inadequate monitoring and identity governance can lead to cumulative effects overall (IBM Security, 2023).

## 7.3 Data Exfiltration and Payload Deployment

In the Suffolk County attack, exfiltration of data was carried out before deploying ransomware: This is characteristic of ALPHV's "double ransom" approach. Legal, financial and personal information, which was handled by both individuals and businesses, was extracted enabling the attackers to undertake additional threats about releasing dump trucks of public records even if systems encrypted. This method serves to give attackers more bargaining chips. Even if there is a backup system, this will not help victims. (BlackCat Ransomware Attacks Not Merely a Byproduct of Bad Luck, 2022)

As soon as the exfiltration was completed, the ransomware virus was deployed simultaneously on all systems in a well-coordinated campaign. BlackCat (Software S1068), according to MITRE ATT&CK, is explicitly associated with Data Encrypted for Impact and related impact techniques aimed at disrupting availability or compelling a payment (BlackCat, Software S1068 | MITRE ATT&CK®, 2021). ALPHV is a piece of ransomware software, developed in Rust, which is optimized for efficiency and evasion; this means rapid encryption of all essential systems. The results were an explosion in requests for service and blocking off county operations. These acts correspond with the MITRE ATT&CK categories Exfiltration (TA0010) and Impact (TA0040).

## 7.4 Mapping to the MITRE ATT&CK Framework with Case

Lastly, the actions have a corresponding log: As soon as the offenders had access to the system, their tactics are more reminiscent of the strategies of BlackCat (S1068) in the MITRE ATT&CT framework. It involves the exploitation of facing applications, credential abuse, lateral movement, data stealing and eventually organized ransomware release (BlackCat, Software S1068 MITRE ATT&CK(r), 2021) The attackers exploited technical vulnerabilities, governance vulnerabilities, and subsequent lateral movement without interruption using

various ATT&CK techniques to steal data. The case demonstrates that the ransomware activity is organized campaign-based instead of one-time business activity, and the defensive strategy must be based on the ATT&CK.

## 8. Conclusion of Section A

The ransomware attack on the Suffolk County, focusing on its long period, significant damage to its operations, and organizational failures. The researchers found out that lucrative state mechanisms and valuable information were targeted to be most disrupted and extorted. Cybercrime profile reports that ALPHV is a highly organized, financial incentive ransomware-as-a-service organization which operates using double-extortion tactics. Analysing the attack using the MITRE ATT&CK framework which incorporated BlackCat (Software S1068), the attack was planned and executed in multiple phases, portrayed by inappropriate patch management, disjointed governance, and delayed response. These observations emphasize the need to establish an active security management system, centralized control, and early detection of threats.

# Section B

## 9. Breach and Attack Simulation Plan

There is no direct usage of the Log4Shell (CVE-2021-44228) vulnerability that was used in the simulation. Rather, the specific attack behaviour is modeled as a simulated event of an unauthenticated execution of a remote command (RCE) on a vulnerable Java-like service. The input is in this case under control of the attacker thus leading to service-initiated execution which can be viewed in host-based logs. This simulation is specially crafted to exhibit behavioural equivalence to the exploitation of Log4Shell, i.e. the shift in external input to execution and the production of forensic artefacts and not a copy of the exploit code.

## 10. Reconnaissance

### Introduction

In this phase it is used to define the context of the attackers and victims on the network and ensure the attack surface that is reachable is known before any true exploitation can take place. It is to generate justifiable evidence on the identification of targets, exposure to services and the time correlation with host telemetry.

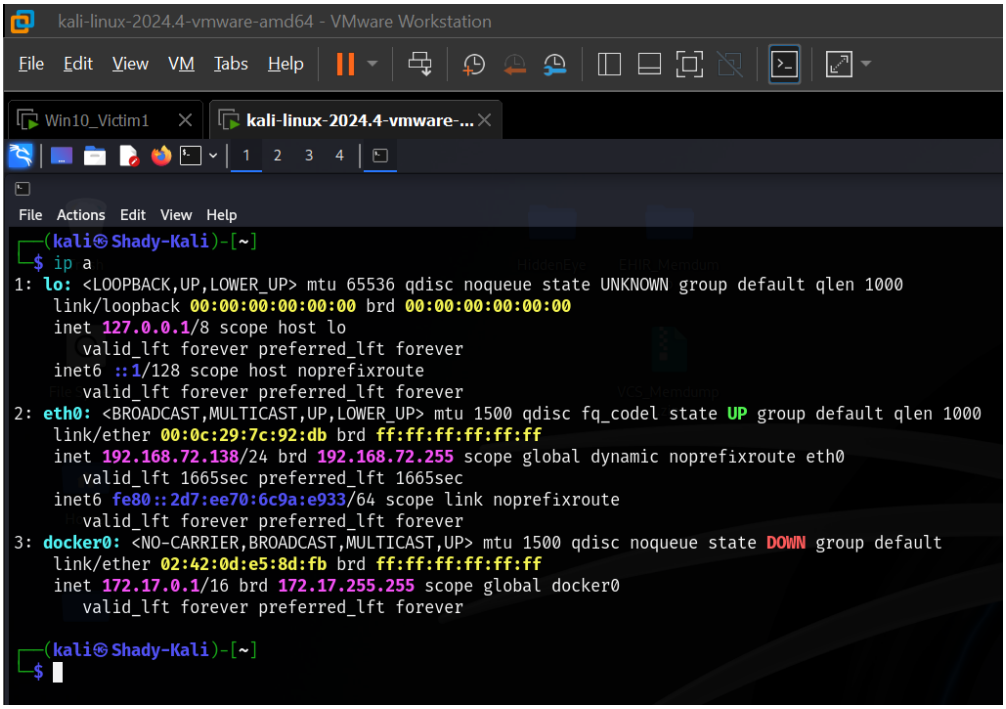



*Figure 3:Attacker network interface verification (ip a) showing the attacker IP used as the traffic source.*

Proves the active interface of the attacker host and source IP, which is the required attribute to attribute later logs/pcap traffic. The IP serves as source of attacks origin which is the reference point of all reconnaissance activities.

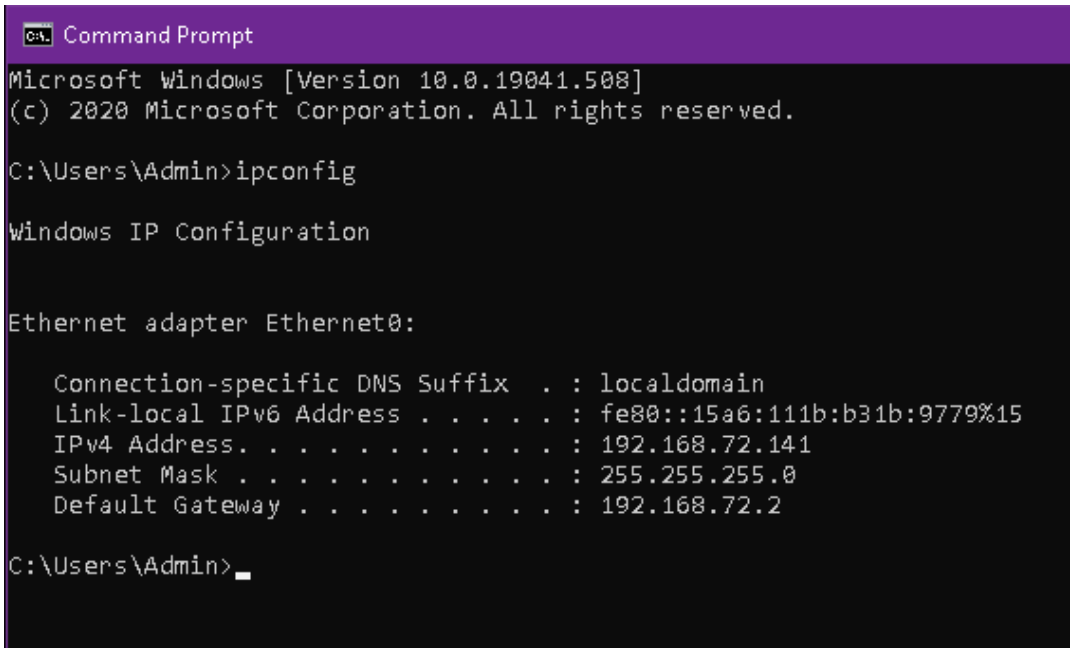



*Figure 4: Verifying the IP addresses of the victims (ipconfig).*

*Authenticates the IP and network context of the victim host and allows proper comparison of attacker-generated traffic with the artefacts and logs generated on the victim side.*

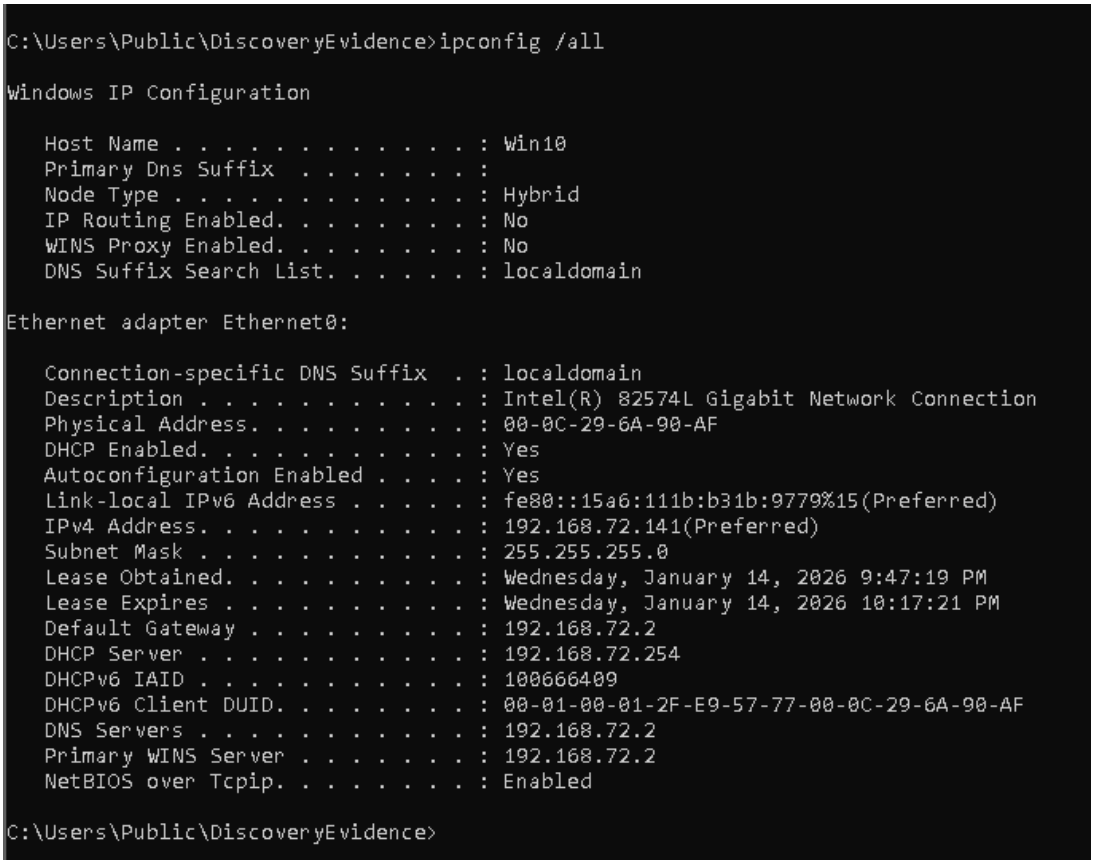



*Figure 5: Detailed victim host network configuration (IP, gateway, DNS).*

Gathers information of environment and host network information about the victim (IP address, gateway, DNS, and DHCP) in detail and sets up local discovery evidence, later to be used as a supporting resource in later investigation and in correlation with future investigations.

```
┌──(kali㉿Shady-Kali)-[~]
└─$ ping -c 4 192.168.72.141
PING 192.168.72.141 (192.168.72.141) 56(84) bytes of data.
64 bytes from 192.168.72.141: icmp_seq=1 ttl=128 time=2.14 ms
64 bytes from 192.168.72.141: icmp_seq=2 ttl=128 time=1.27 ms
64 bytes from 192.168.72.141: icmp_seq=3 ttl=128 time=2.40 ms
64 bytes from 192.168.72.141: icmp_seq=4 ttl=128 time=1.81 ms

── 192.168.72.141 ping statistics ──
4 packets transmitted, 4 received, 0% packet loss, time 3007ms
rtt min/avg/max/mdev = 1.270/1.905/2.399/0.421 ms
```

*Figure 6: ping -c 4 192.168.72.141 to ensure that the victim can be connected to prior to the scanning.*

Checks the victim host can be accessed across the network and subsequently undergoes additional discovery measures. This facilitates a clean sequence: confirming connectivity.

```
┌──(kali㉿Shady-Kali)-[~]
└─$ sudo nmap -Pn -T3 192.168.72.141
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-01-14 07:30 EST
Nmap scan report for 192.168.72.141
Host is up (0.0021s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE SERVICE
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
MAC Address: 00:0C:29:6A:90:AF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.04 seconds
```

*Figure 7:nmap -Pn -T3 192.168.72.141 showing exposed services/ports (e.g., 135/139/445/3389).*

Determines the presence of exposed network services as well as reachable ports on the victim host that define the externally accessible attack surface before any simulated initial access activity.

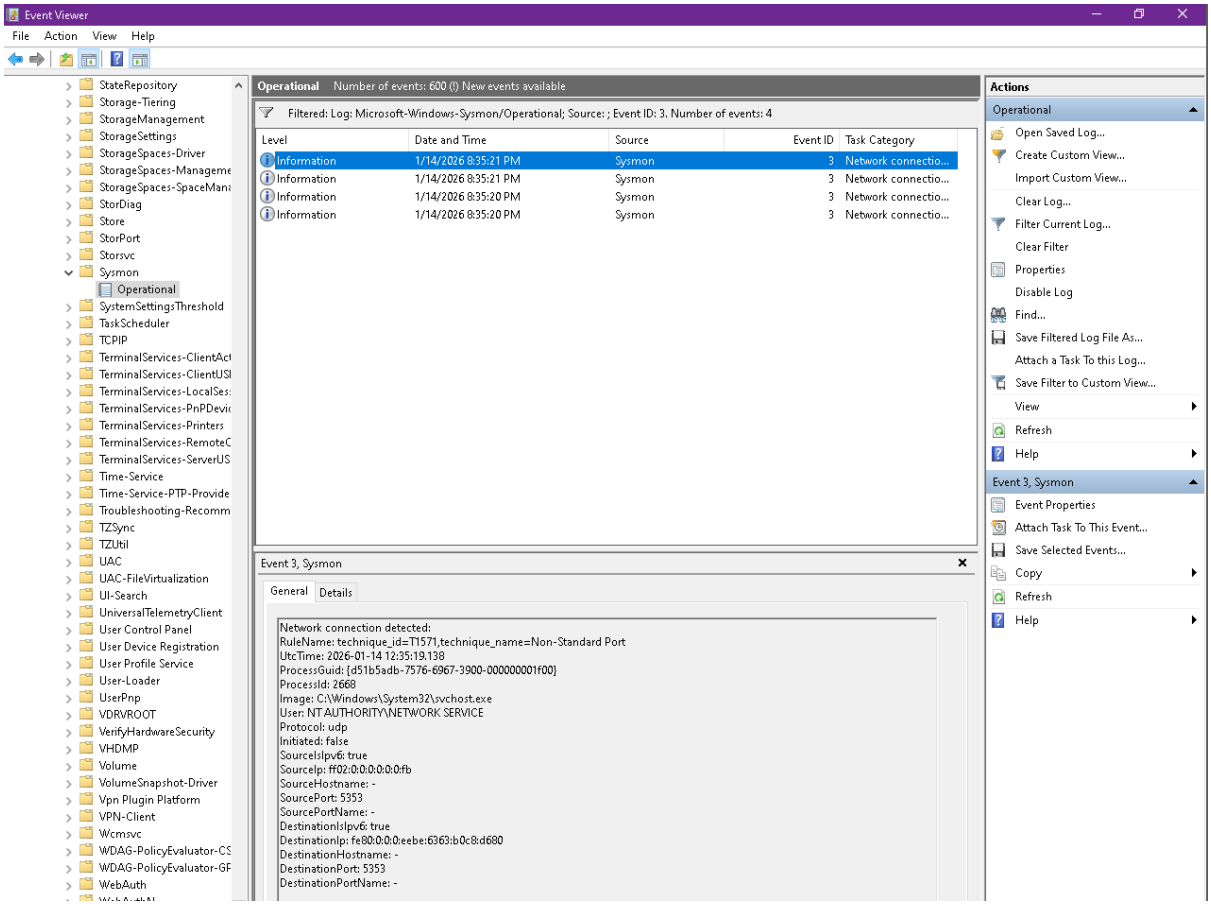
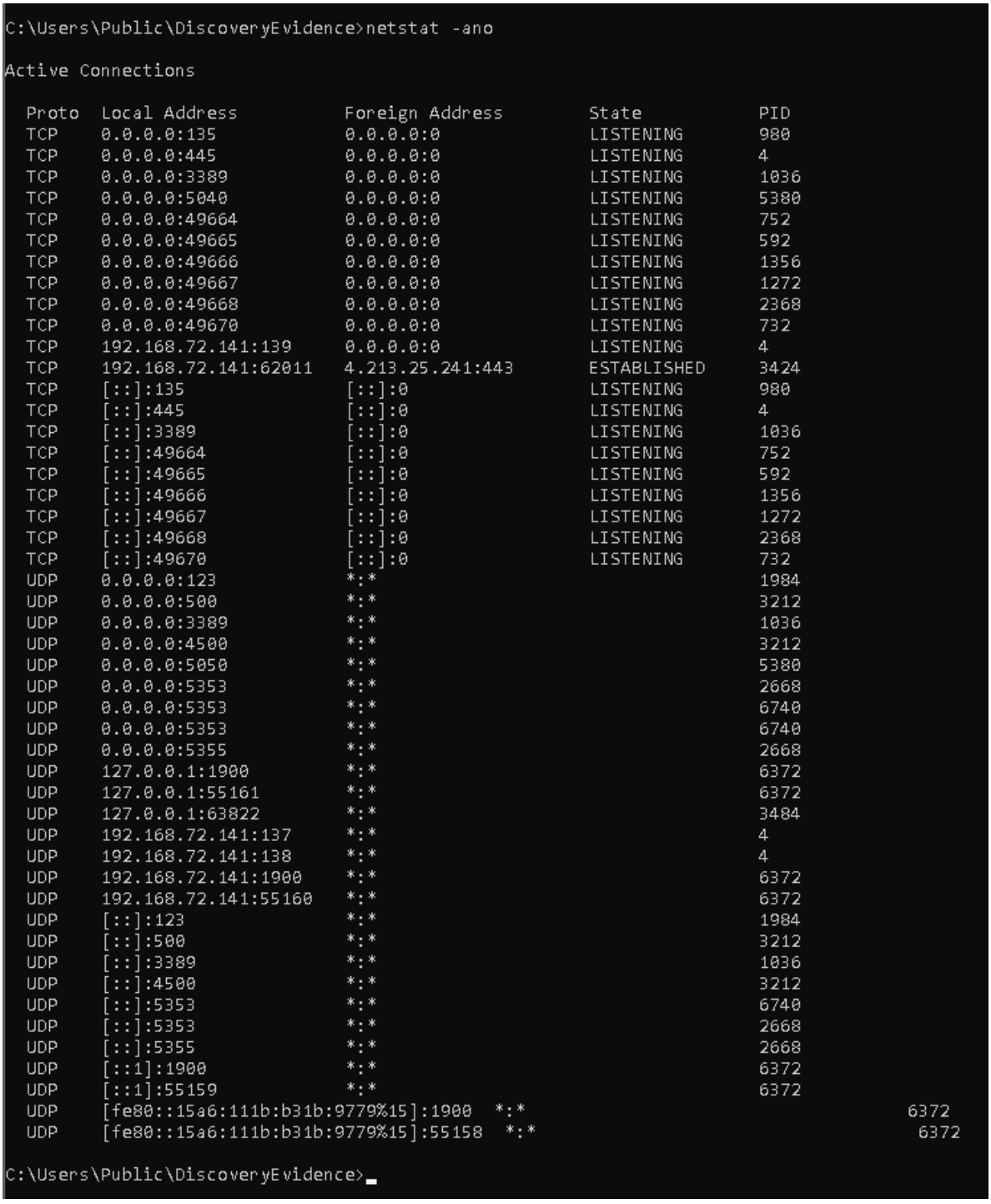



*Figure 8:Sysmon: Event ID 3 (Network Connection) event telemetry that shows network activity can be used to correlate it with scans/discovery.*



```
C:\Users\Public\DiscoveryEvidence>netstat -ano

Active Connections

  Proto  Local Address          Foreign Address        State           PID
  TCP    0.0.0.0:135            0.0.0.0:0              LISTENING       980
  TCP    0.0.0.0:445            0.0.0.0:0              LISTENING       4
  TCP    0.0.0.0:3389           0.0.0.0:0              LISTENING       1036
  TCP    0.0.0.0:5040           0.0.0.0:0              LISTENING       5380
  TCP    0.0.0.0:49664          0.0.0.0:0              LISTENING       752
  TCP    0.0.0.0:49665          0.0.0.0:0              LISTENING       592
  TCP    0.0.0.0:49666          0.0.0.0:0              LISTENING       1356
  TCP    0.0.0.0:49667          0.0.0.0:0              LISTENING       1272
  TCP    0.0.0.0:49668          0.0.0.0:0              LISTENING       2368
  TCP    0.0.0.0:49670          0.0.0.0:0              LISTENING       732
  TCP    192.168.72.141:139     0.0.0.0:0              LISTENING       4
  TCP    192.168.72.141:62011   4.213.25.241:443       ESTABLISHED     3424
  TCP    [::]:135               [::]:0                 LISTENING       980
  TCP    [::]:445               [::]:0                 LISTENING       4
  TCP    [::]:3389              [::]:0                 LISTENING       1036
  TCP    [::]:49664             [::]:0                 LISTENING       752
  TCP    [::]:49665             [::]:0                 LISTENING       592
  TCP    [::]:49666             [::]:0                 LISTENING       1356
  TCP    [::]:49667             [::]:0                 LISTENING       1272
  TCP    [::]:49668             [::]:0                 LISTENING       2368
  TCP    [::]:49670             [::]:0                 LISTENING       732
  UDP    0.0.0.0:123            *:*                                    1984
  UDP    0.0.0.0:500            *:*                                    3212
  UDP    0.0.0.0:3389           *:*                                    1036
  UDP    0.0.0.0:4500           *:*                                    3212
  UDP    0.0.0.0:5050           *:*                                    5380
  UDP    0.0.0.0:5353           *:*                                    2668
  UDP    0.0.0.0:5353           *:*                                    6740
  UDP    0.0.0.0:5353           *:*                                    6740
  UDP    0.0.0.0:5355           *:*                                    2668
  UDP    127.0.0.1:1900         *:*                                    6372
  UDP    127.0.0.1:55161        *:*                                    6372
  UDP    127.0.0.1:63822        *:*                                    3484
  UDP    192.168.72.141:137     *:*                                    4
  UDP    192.168.72.141:138     *:*                                    4
  UDP    192.168.72.141:1900    *:*                                    6372
  UDP    192.168.72.141:55160   *:*                                    6372
  UDP    [::]:123               *:*                                    1984
  UDP    [::]:500               *:*                                    3212
  UDP    [::]:3389              *:*                                    1036
  UDP    [::]:4500              *:*                                    3212
  UDP    [::]:5353              *:*                                    6740
  UDP    [::]:5353              *:*                                    2668
  UDP    [::]:5355              *:*                                    2668
  UDP    [::1]:1900             *:*                                    6372
  UDP    [::1]:55159            *:*                                    6372
  UDP    [fe80::15a6:111b:b31b:9779%15]:1900  *:*                                    6372
  UDP    [fe80::15a6:111b:b31b:9779%15]:55158  *:*                                    6372

C:\Users\Public\DiscoveryEvidence>
```

*Figure 9:netstat -ano enumerating listening ports and active connections (baseline service exposure).*

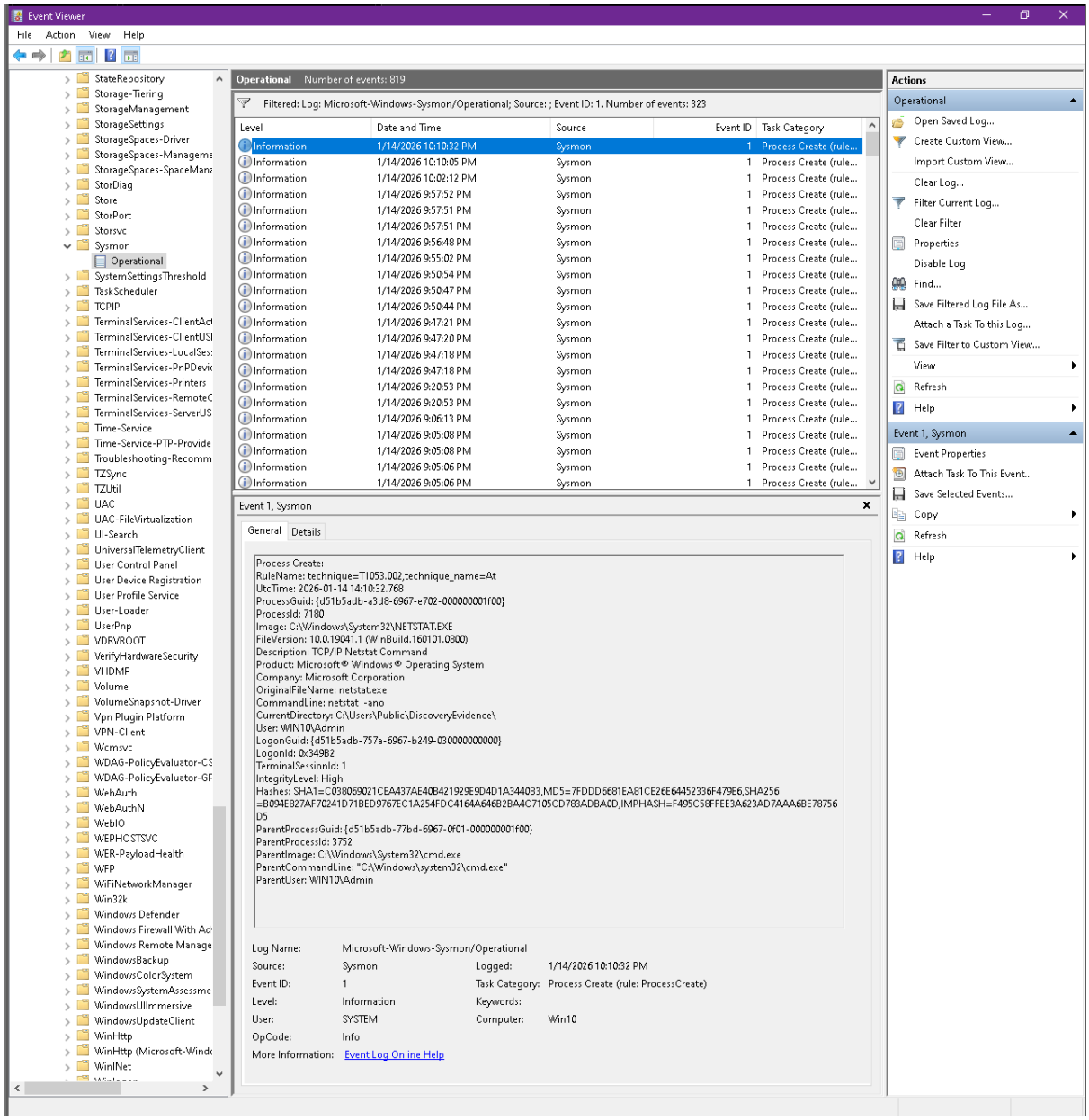



*Figure 10:Sysmon: Event ID 1 (Process Create) showing netstat.exe execution + command line.*

Authenticates the netstat.exe full-command-line execution in Sysmon and makes it possible to correlate local discovery actions and endpoint forensic telemetry.

# 11. Initial Access

## Introduction

This phase indicates the transition between the reconnaissance step and the first access by imitating the behaviour of Log4Shell, where the input that the attacker has control over is sent to an available Java-like service without authentication. Instead of using the vulnerability of Log4Shell as a pivot, this step shows how input provided externally can be used in a service and produce artefacts related to execution as is evident on the host. This abstraction is behaviourally equivalent to CVE-2021-44228 initial access without imitating exploits.

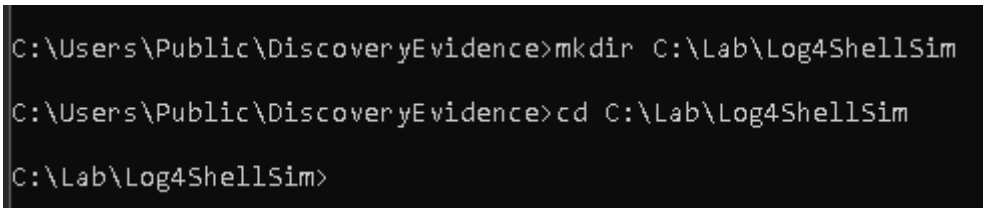



*Figure 11: Preparation of isolated working directory for Log4Shell behaviour simulation.*

Creates a special directory on the victim machine in which to prepare the staged Log4Shell simulation artefacts. This will provide isolation to system files or files generated during the attack and the traceability of these files will be enhanced.

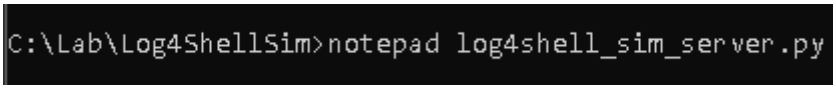



*Figure 12:Opening the file log4shellsimserver.py with Notepad in order to generate the simulated vulnerable HTTP service.*

Demonstrates how to prepare a clean, non-destructive HTTP service to represent a vulnerable entry point. The step prepares the attack surface as needed in the demonstration of initial access behaviour.




*Figure 13: Server logic mapping attacker input to non-destructive execution markers.*

Demonstrates server logic - request parsing and simulated execution invoke how incoming requests are parsed and evaluated for the trigger token. This model how attacker input can lead to execution-related artefacts while remaining safe and controlled.

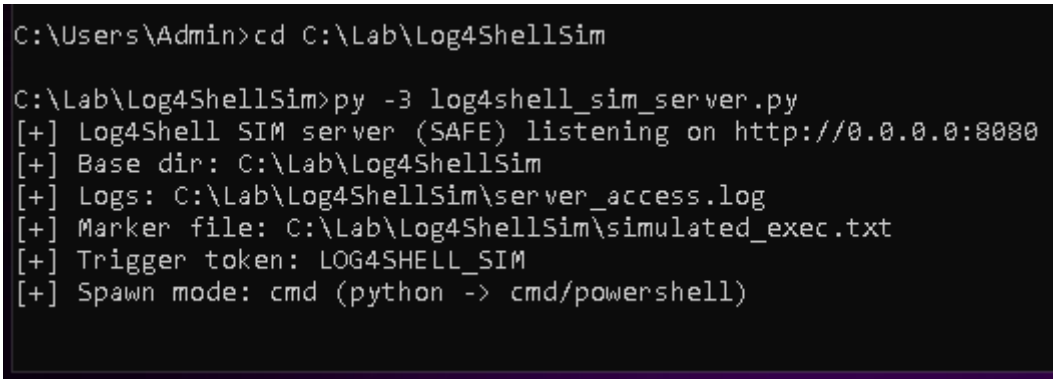



*Figure 14:To begin the simulation server (py -3 log4shell simserver.py) and to verify that it is listening on the desired host/port, as well as writing evidence output.*

Then the python3 log4shellsimserver.py Checks the simulated service is up and, on the host, and port. This is whereby the victim system can be externally accessible to the first attempts at accessing the system.

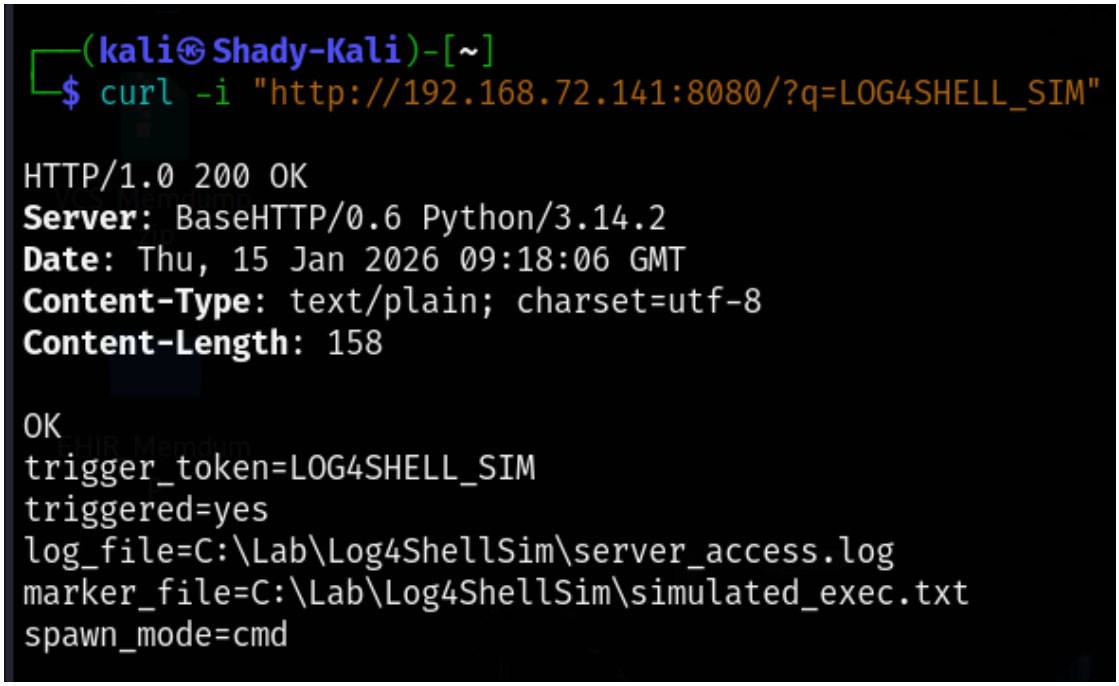



*Figure 15:Kali curl request to the victim HTTP endpoint which services the LOG4SHELLSIM token, which is an initial access via exposed service.*

Initial access occurs when the first communication between the attacker and the exposed service occurs.The successful response proves that the input that was set by the attacker made it to the service and provoked simulated artefacts of execution.

# 12. Execution

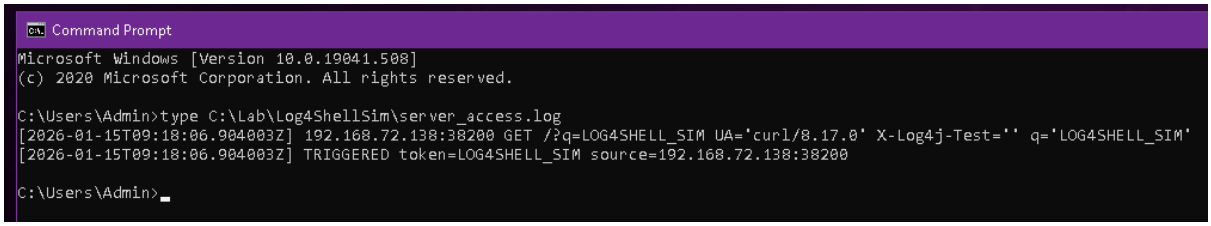



*Figure 16:Access to serveraccess.log that has captured the inbound request and the server-side entry, TRIGGERED record that verifies a switch between a first contact to execution.*

Confirms that attacker-controlled input was successfully delivered to the exposed service and activated execution-related behaviour. This log entry marks the transition from initial access into the execution phase.

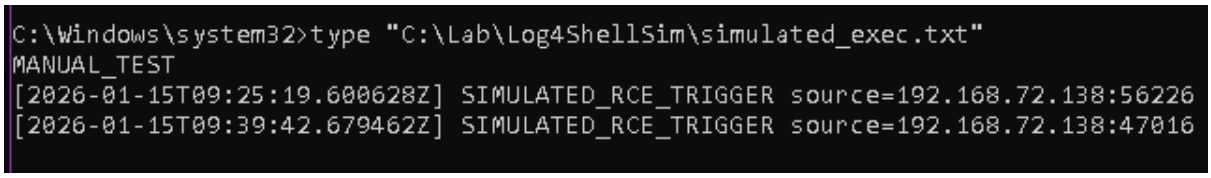



*Figure 17: simulated_exec.txt showing execution marker.*

Provides non-destructive evidence that execution-like behaviour was triggered because of attacker-controlled input. The timestamps enable correlation with Sysmon and Windows Security logs for forensic reconstruction.

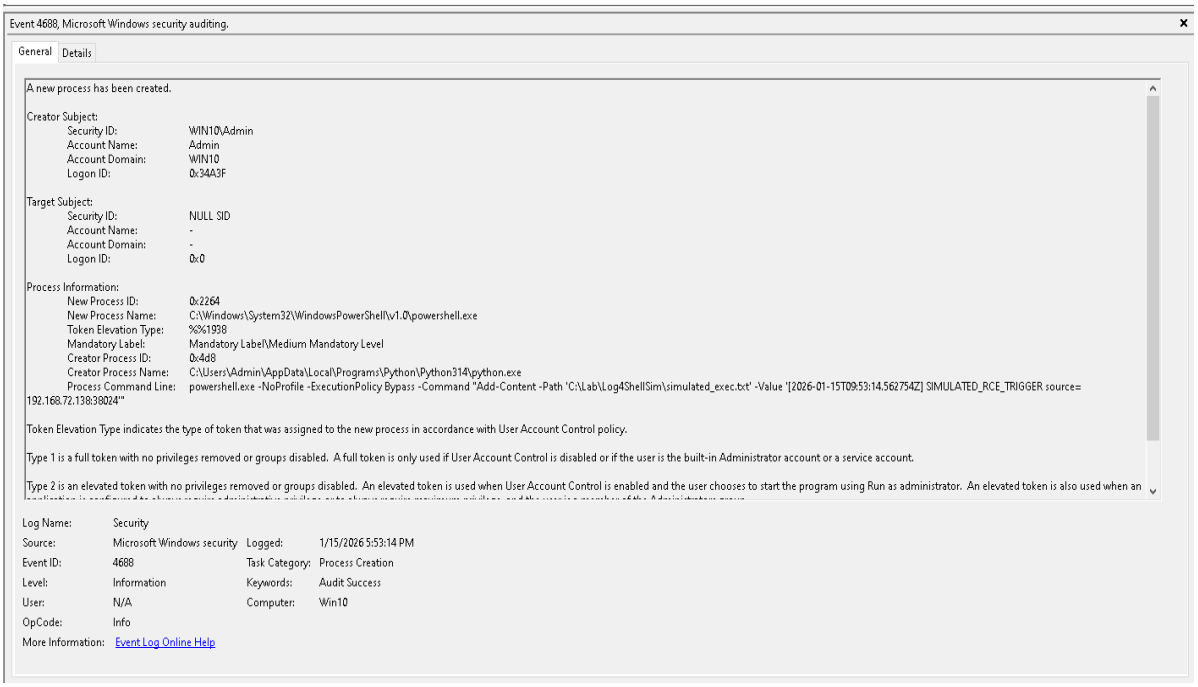



*Figure 18: Windows Security Event ID 4688 of service-initiated creation of processes.*

This event captures the process creation and command-line setting involved in the simulated running. Combined with Sysmon Event ID 1, it validates a parent-child process association that is triggered by a service, and its execution is initiated by a service protocoled to the network, but not by an interactive user process. This is absent of an authentic administrative context and is relative to the authorised activity, which justifies the assignment of the behaviour to the category of Log4Shell-style remote code execution as an activity on the behavioural level.

# 13. Impacts

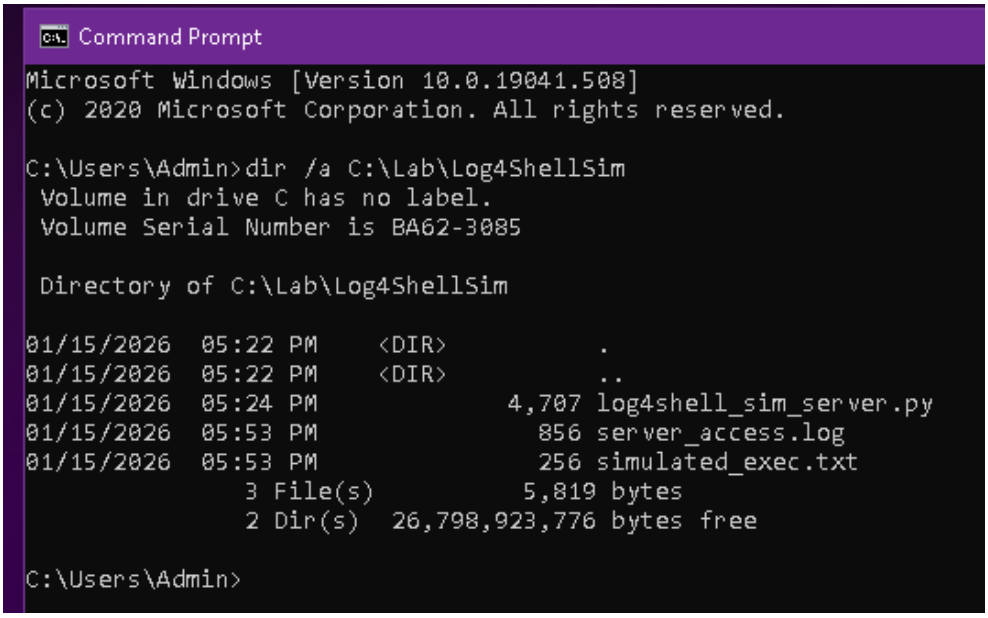



*Figure 19:Checking simulation artefacts the artefact of the simulation was checked on the victim host (dir /a C:\Lab\Log4ShellSim), where the server script as well as evidence files generated by simulation (serveraccess.log, simulatedexec.txt) were confirmed.*

Confirms that execution-related artefacts were written to disk on the victim system because of the simulation. The presence of these files demonstrates a tangible system-level impact.

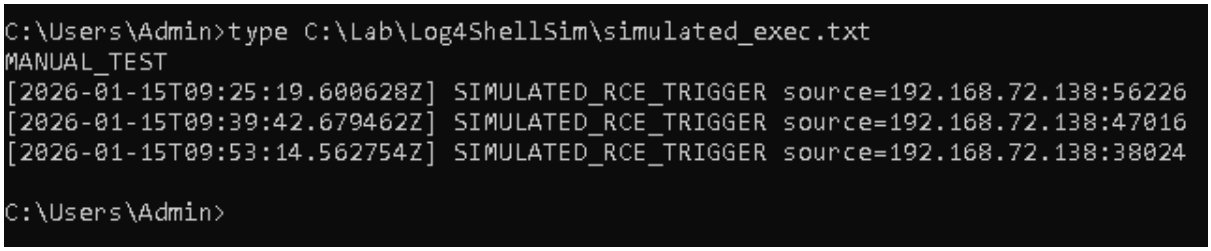



*Figure 20:The simulationexec.txt This is visualized by displaying the non-destructive evidence of the simulation of the execution triggered by attacker traffic, the presence of timed SIMULATED_RCE_TRIGGER objects.*

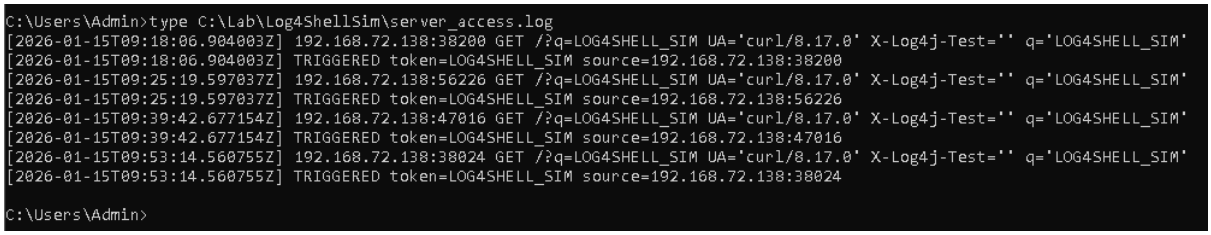



*Figure 21: server_access.log showing inbound request and "TRIGGERED" marker.*

The presence of this log proves the attacker-to-victim interaction as the incoming requests are compared to the markers of the activated-TRIGGERed. Concisely, it demonstrates that it was not an internal entity but an outer attacker activity that had the visible effect.

# 14. Detection Action Plan

## Introduction

Detection Action Plan aims to detect and confirm the presence of the Log4Shell-style execution behaviour by analyzing observable artefacts both on a host and a network instead of exploit payload. Although the resulting artefacts resemble those produced by Log4Shell exploitation, no vulnerable library or exploit code is used; instead, detection is based on correlating service-initiated execution, process lineage, and audit telemetry to support reliable post-incident analysis.

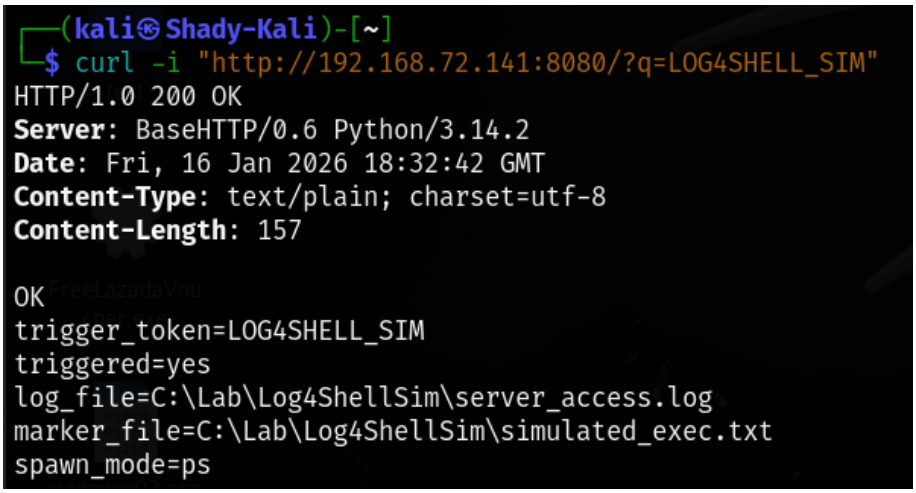



*Figure 22:Attacker request (curl) of initiating activity (the initiating request) by the victim HTTP service (proceeding in the other direction) returning "triggered=yes" and then the subsequent detection correlation is to be triggered.*

Establishes the initiating attacker action that detection should anchor on, including timing and successful service response. This is used as the reference event to correlate with Wireshark traffic and host-side logs.

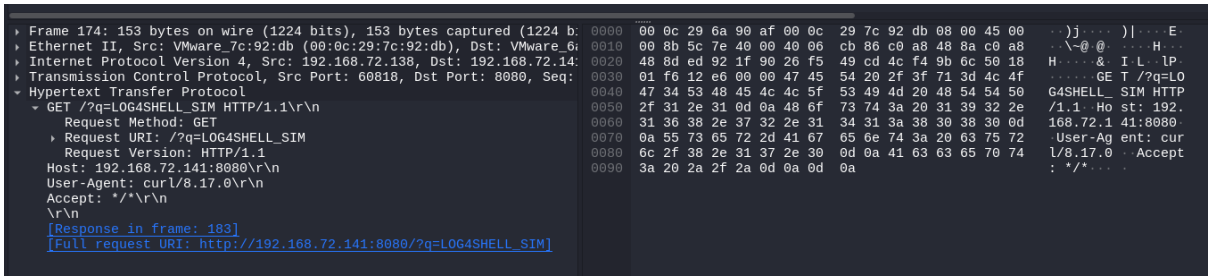



*Figure 23:Wireshark packet detail view decoding the HTTP request (URI/query token), which presents packet-level indicators of signature/indicator matching and reconstructing of the request context.*

Provides packet-level evidence of the exact indicator (query token) and request context for signature/IOC matching. Enables reconstruction of "what was sent" and strengthens detection logic beyond summary traffic listings.

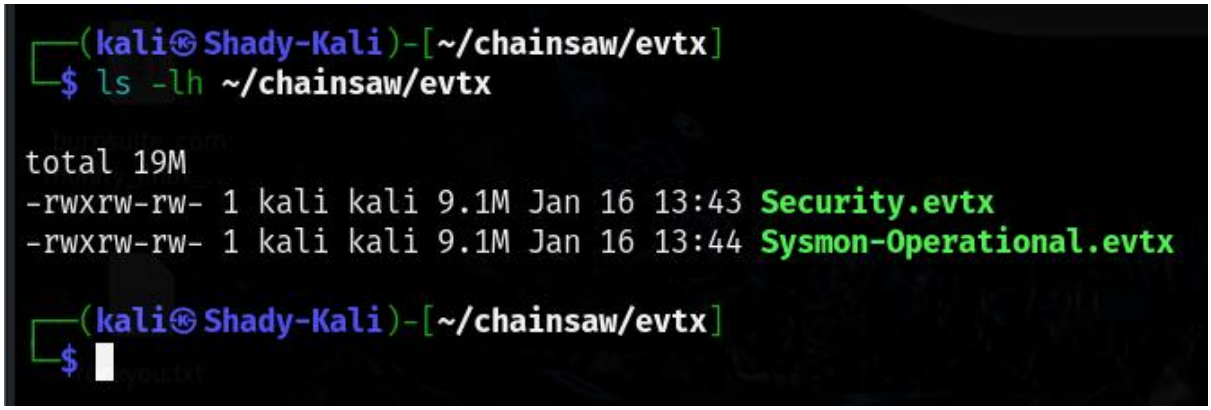



*Figure 24:Kali evidence staging exported windows event logs (security.evtx and Sysmon-Operational.evtx) ready to be offline hunted and detected.*

Confirms log acquisition and staging for offline hunting, ensuring the detection process is repeatable and auditable. Demonstrates controlled evidence handling before running triage searches (important for forensics credibility).

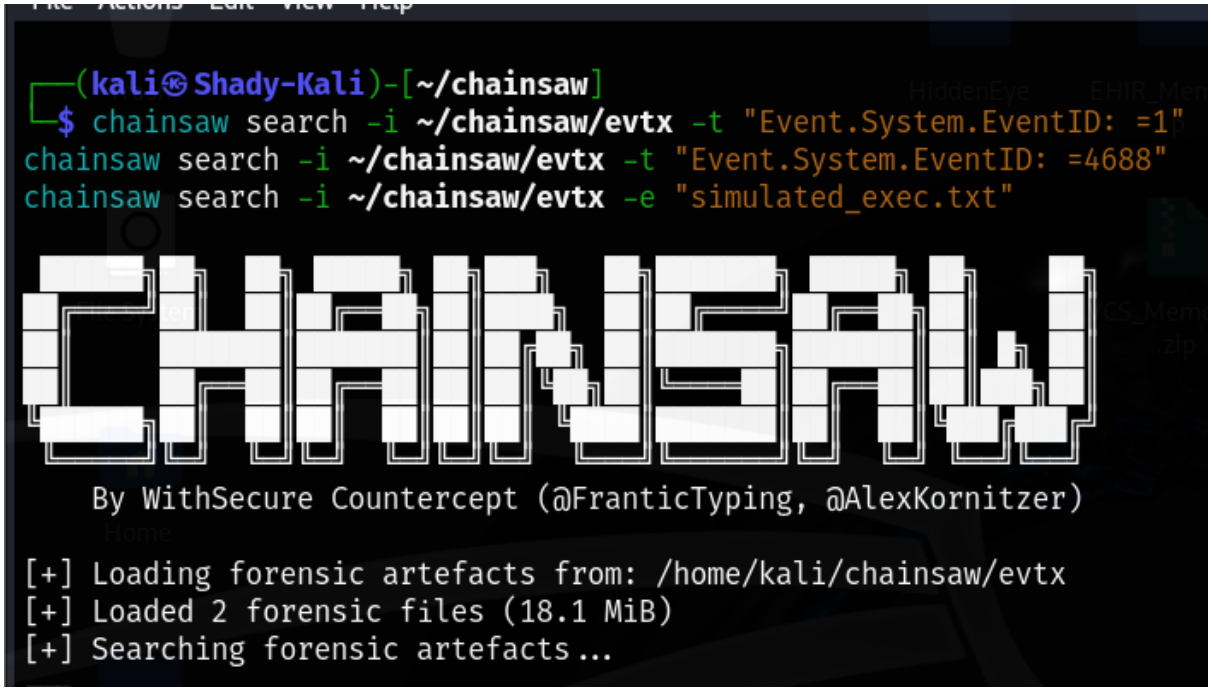



*Figure 25:execution with focused searches on important artefacts (e.g., Sysmon Event ID 1 and Security Event ID 4688), which then lets additional triage and detection validation scale.*

In this section, we seek all the exported logs in search of important artifacts related to the execution and auditing process very fast.

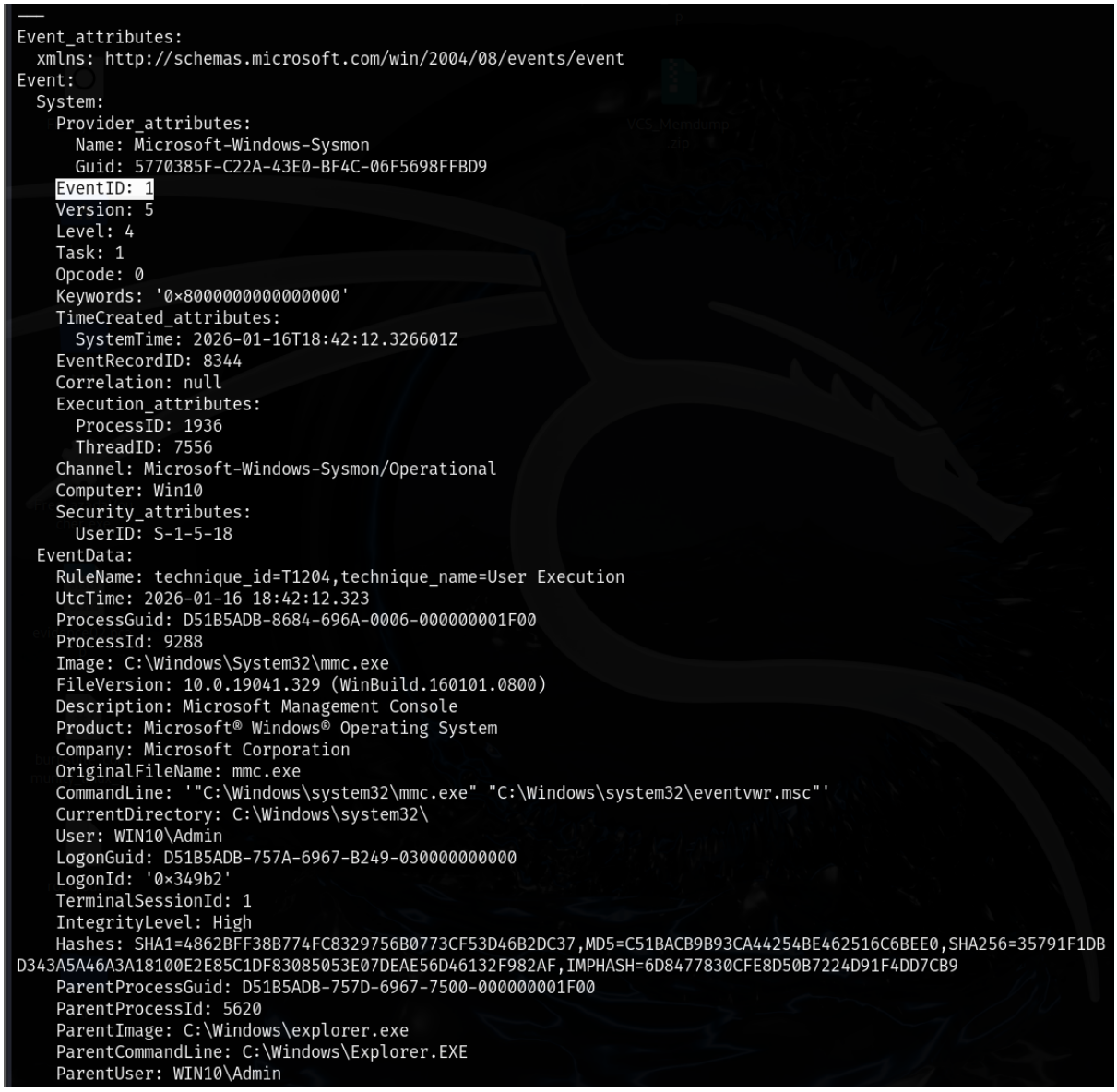



*Figure 26: Parsed Sysmon Event ID 1 of analyst- initiated process creation (mmc.exe / Event Viewer) when investigating the events.*

This event reflects investigator activity while reviewing logs and is included to demonstrate host interaction during analysis. It is not associated with attacker-triggered execution.

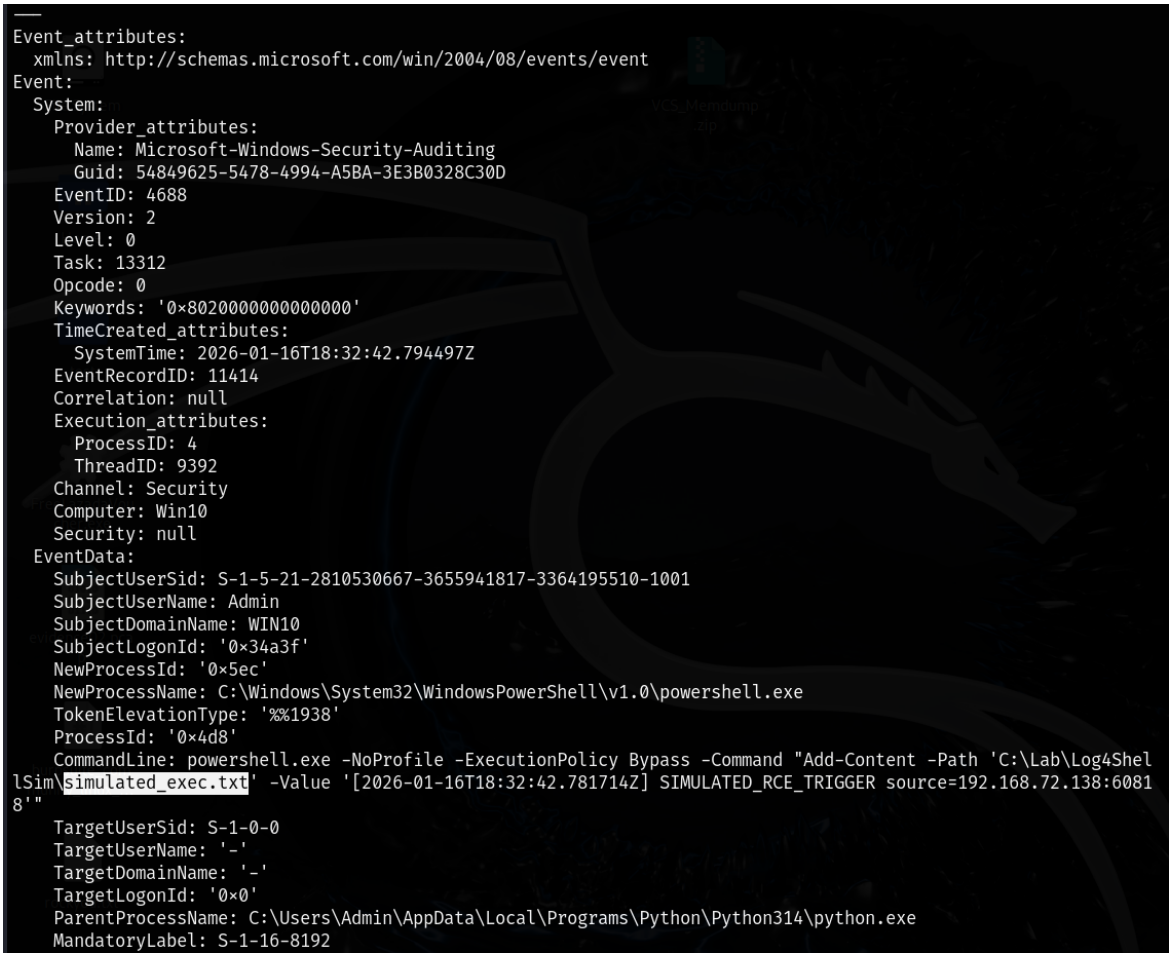



*Figure 27: Windows Security 4688 command line and new process creation.*

Validates that process creation, command-line activity, which when combined with Sysmon Event ID 1, confirms service-initiated execution, was successfully captured by the windows audit policy and does not require any one single log to be relied on.

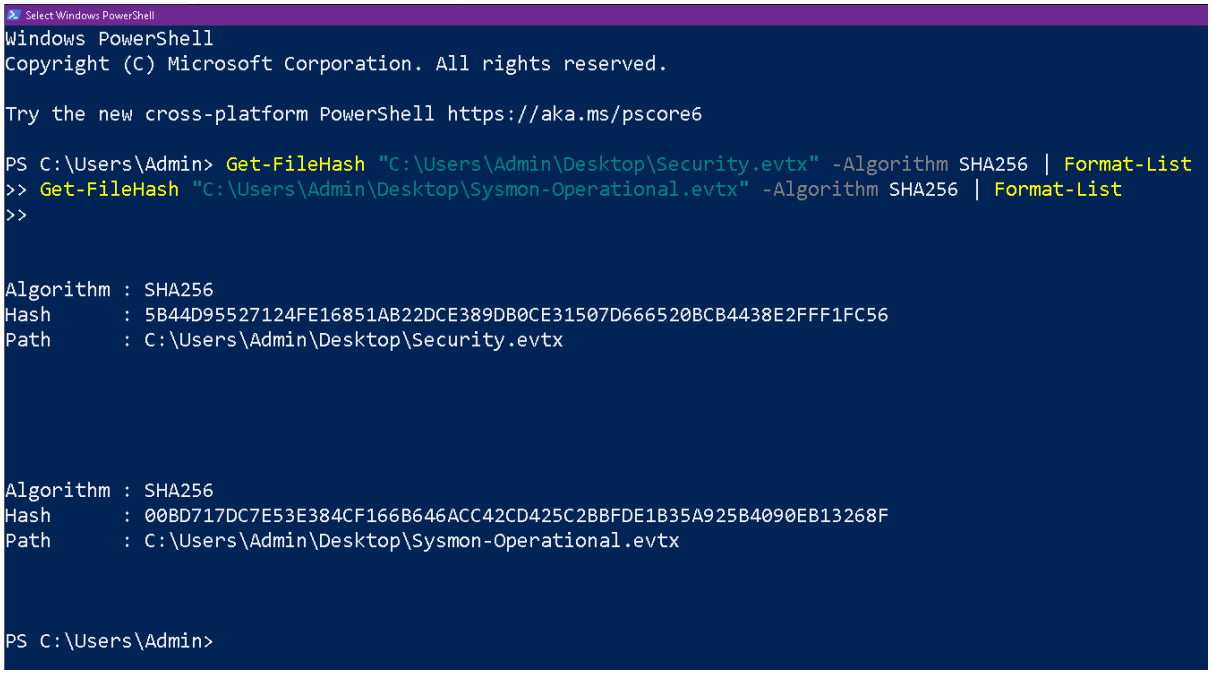



*Figure 28: SHA-256 hash of available Security.evtx and Sysmon logs..*

SHA-256 hash records of exported Security and Sysmon event logs are taken to ensure interaction integrity and chain of custody, to ensure that the logs were not altered after collecting and containing them.

## 15. Forensics Analysis (PCAP + EVTX Triage Findings)

The forensic examination involved windows security and Sysmon EVTX logs, service-level artefacts, and specific packet captures (PCAP) to rebuild service-initiated execution behaviour and justify the attacker operation and reduce analysis noise. Such high-priority aids quick triaging and assured attribution by aligning the indicators of process creation, command-line execution and network interaction evidence compared to broadening the scope of investigation terms unreasonable and without proportional and relevant artefacts. This targeted artefact choice can allow the confident use of post-incident attribution of service-based execution without having to extend analysis to endpoints and volatile memory absent during the incident under consideration.

## 16. Detection Limitations

Detection in this scenario is subject to several practical limitations. False positives can take place in a system where parent services generate a child process as a legitimate operation, which could mimick behaviour of service-initiated execution. Lack of centralised Security Information and Event Management (SIEM) platform also limits visibility, requiring it to do

correlation on a separate basis, either manually or semi-automatically on each source of logs. Also, network traffic encrypted means that deep packet inspection cannot be done at the network level and hence, the payloads are not readily visible. Consequently, the host-based telemetry, e.g. Sysmon and windows security audit logs, is the major and the most accurate detection method in this simulation.

# 17. Incident Response Plan, Cyber Playbook, and Prevention Action Plan

# 18. Incident Response Plan

This case happens when an unauthenticated request to an exposed service starts the incident, and the service then starts executing as is expected during simulated Log4Shell-like RCE and ransomware early-stage staging. After confirming that the scope is with the service logs, the validation of the execution chain and assets that were affected are done using initial triage through correlating Sysmon telemetry with the service logs and process-creation events in Windows Security. The initial prevention of re-triggering by blocking the vulnerable port and filtering of suspected sources. To maintain evidence, prior to remediation, relevant Sysmon and Security logs should be exported and secured, service logs are to be saved, and key artefacts of the execution marks and packet captures should be safeguarded. Eradication aims at dealing with root causes by using patching and hardening, disabling unneeded components and resetting credentials to avoid persistence with compromised service or administrative accounts. Recovery is the restoration of systems using known-good backups in systematic phases and detection of recomposes. A post-incident review records the chain of events, it discovers why detection and response were inadequate, updates runbooks, and incorporates governance enhancements since disconnected ownership and slow remediation often add dwell time to environments in the public sector.

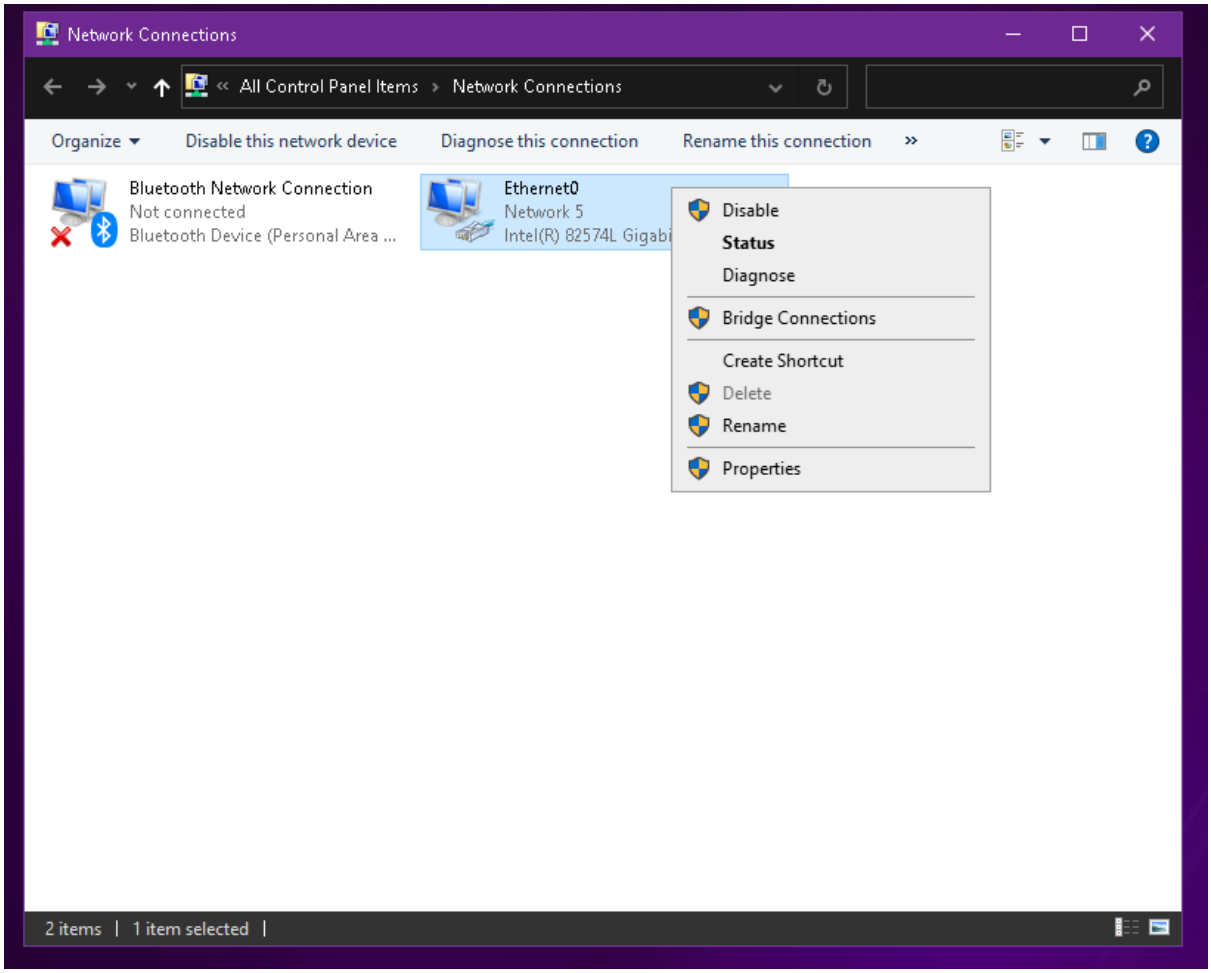



*Figure 29:Containing operations with the active adapter (Ethernet0) by isolating the victim host by opening Network Connections and selecting the active adapter (Ethernet0) as shown in Figure 29.*

This is the first option in terms of how to handle the victim host: the victim host should be confined at the network layer and no more communication with the attacker should occur. This takes care of any further connections coming in as IR activities and evidence processing occur.

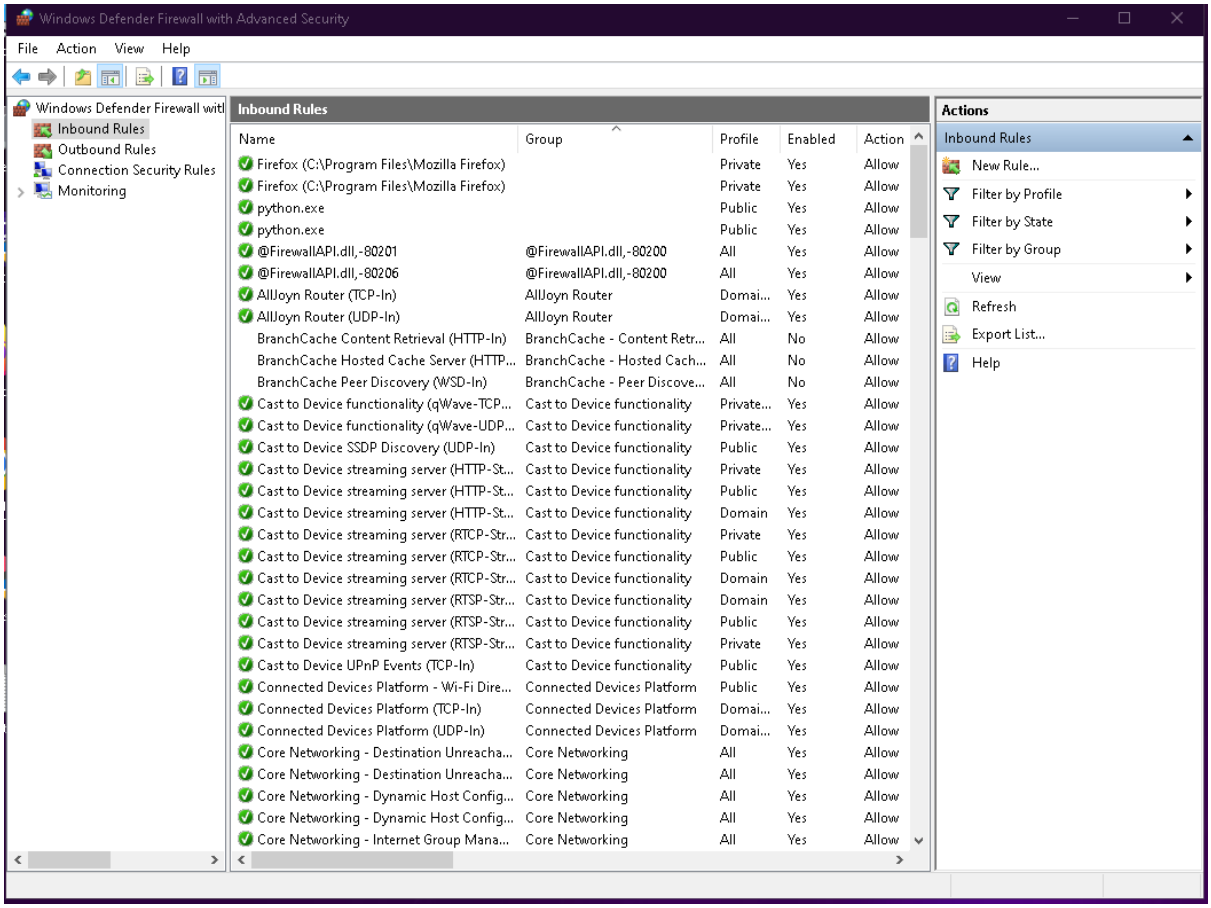



*Figure 30:Accessing Windows Defender Firewall with Advanced Security to manage inbound rules for service containment and creating a new inbound firewall rule.*

Switching the concept of containment of the full isolation to service-level containment through controlling inbound firewall rules. This prepares a target control to block the open service without going fully offline on the webserver.

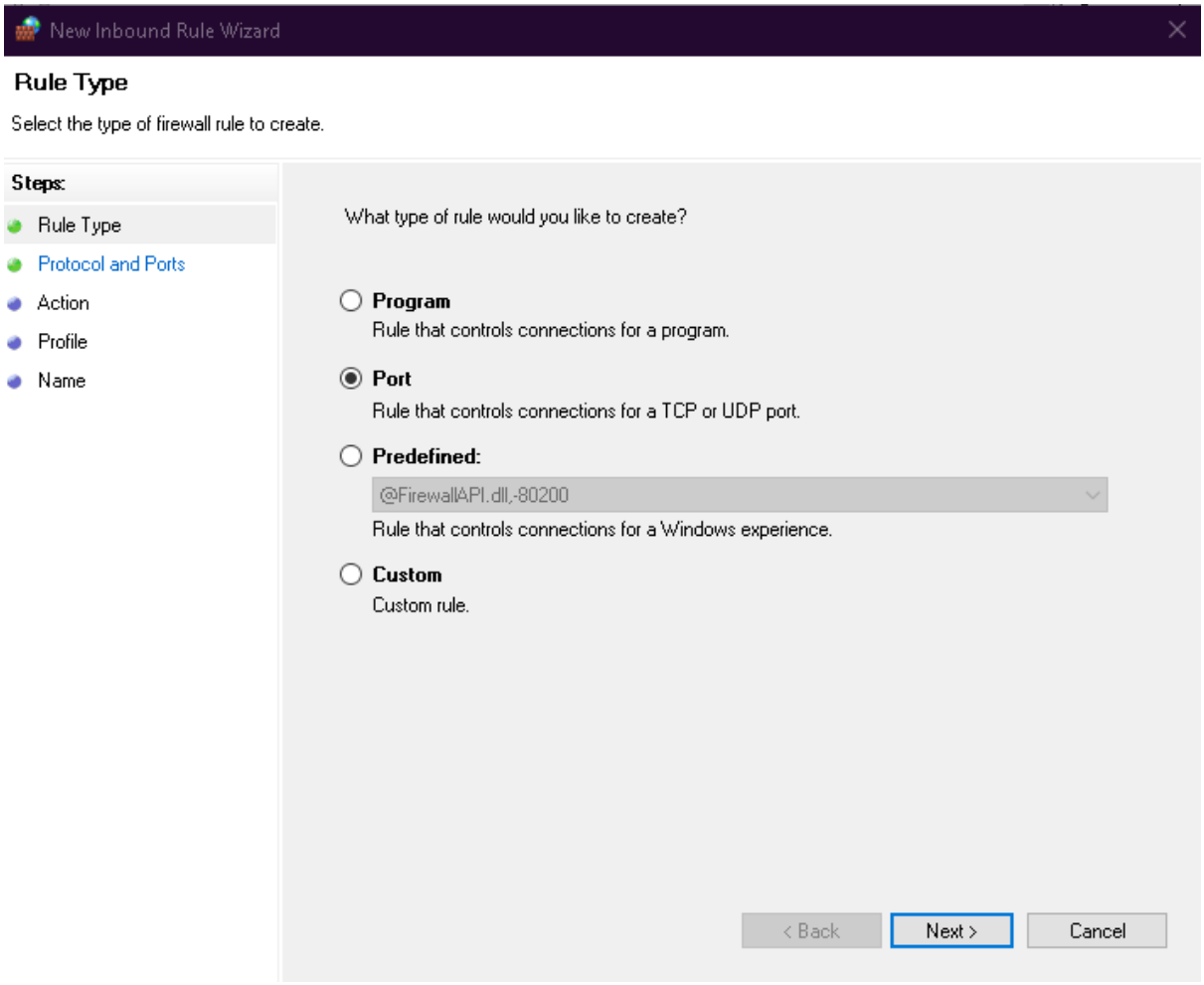



*Figure 31:When choosing the rule type, Port is selected to block the traffic passing to the vulnerable service based on service listening port and not particular application.*

Confirms the containment is port-based, which fits the scenario because the exposure is the HTTP service on 8080.This ensures the block applies even if the service executable changes.

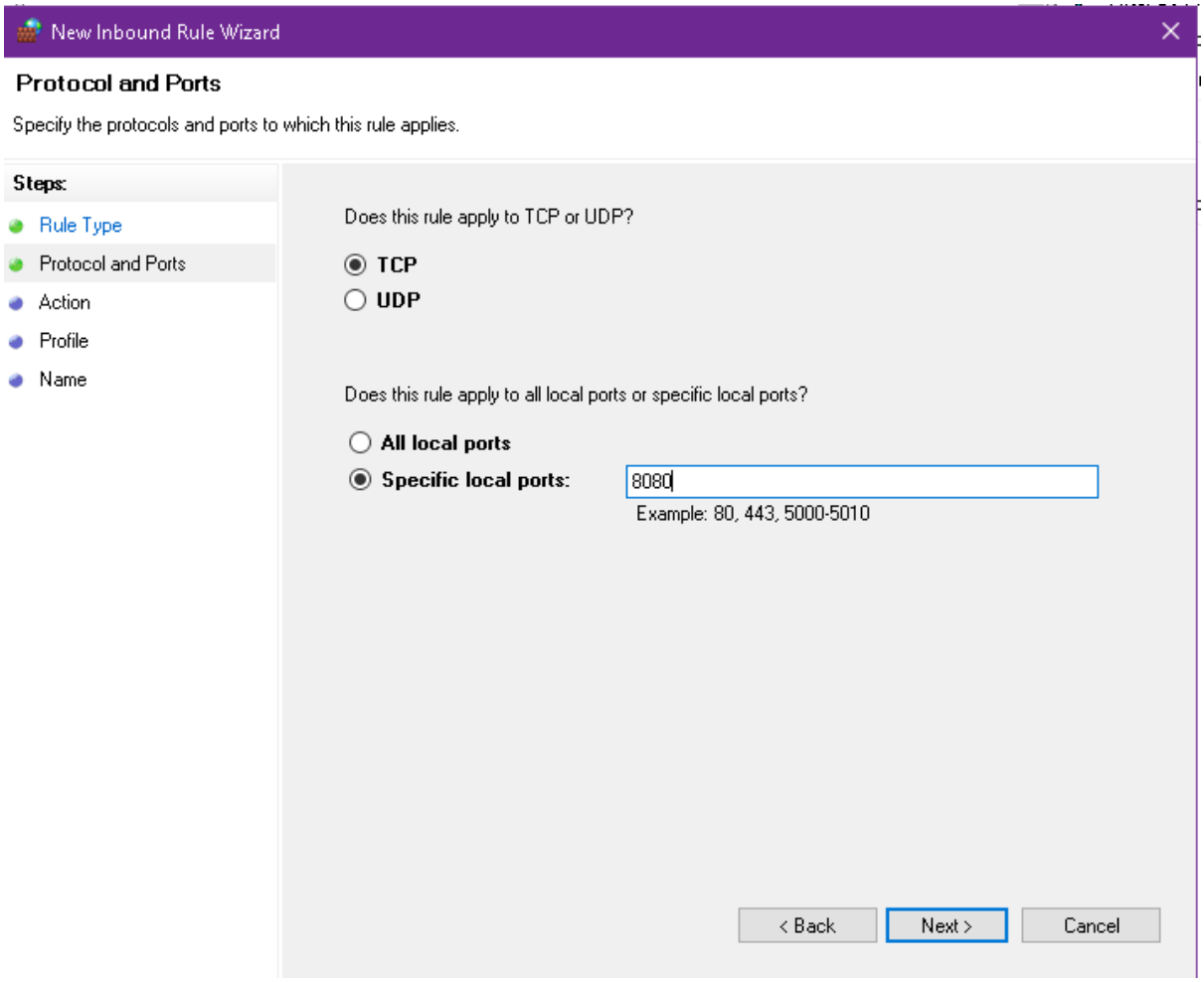



*Figure 32:Setting up the rule on inbound traffic on TCP on specific local port 8080 in such a way that it would simply prevent inbound traffic to the service endpoint.*

Defines the exact scope of containment: block inbound TCP/8080, which is the simulated vulnerable endpoint. This directly disrupts the initial-access path used by the attacker.

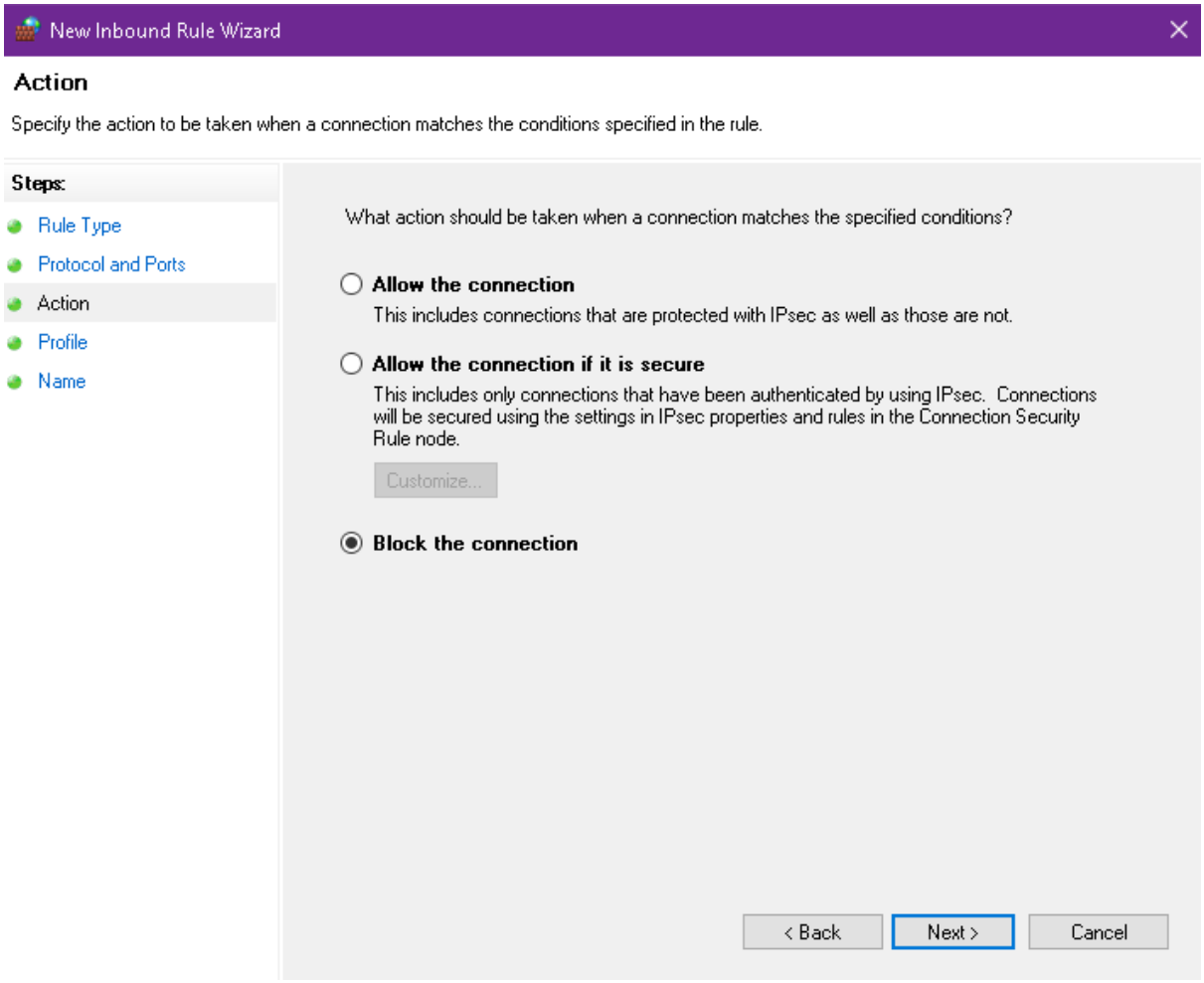



*Figure 33:To force a connection to the port to contain immediately, select the option like Block the connection and block your connection.*

Indicates the containment enforcement mode: it explicitly blocks the traffic instead of admitting it or securing it to a certain degree. This is the final step that prevents new inbound services to the service.

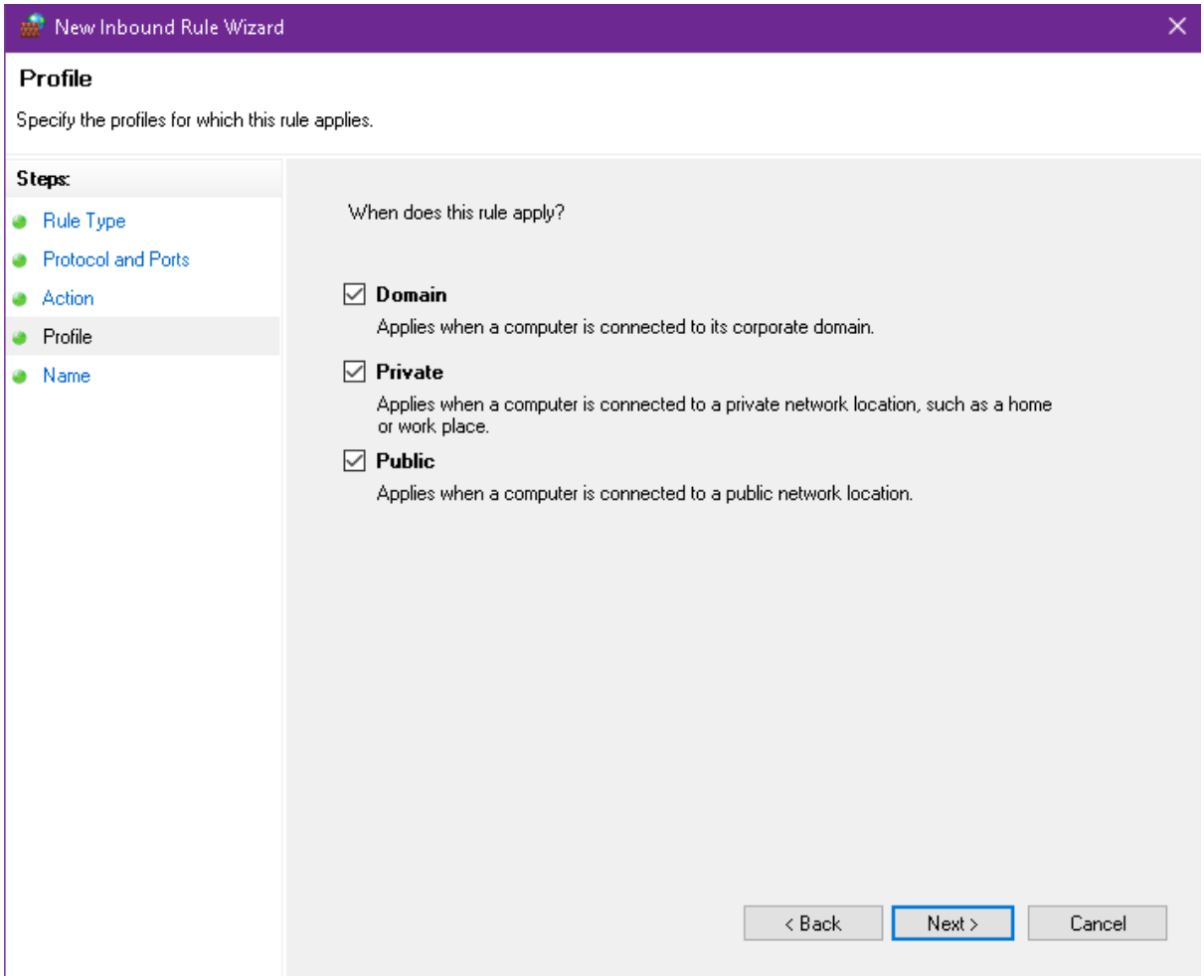



*Figure 34:To implement the firewall block rule on all network profiles (Domain, Private, Public) to have containment is still effective.*

Users the containment rule to all profiles to prevent gaps created by windows network profile changes. This enhances reliability of lab and real world switching.

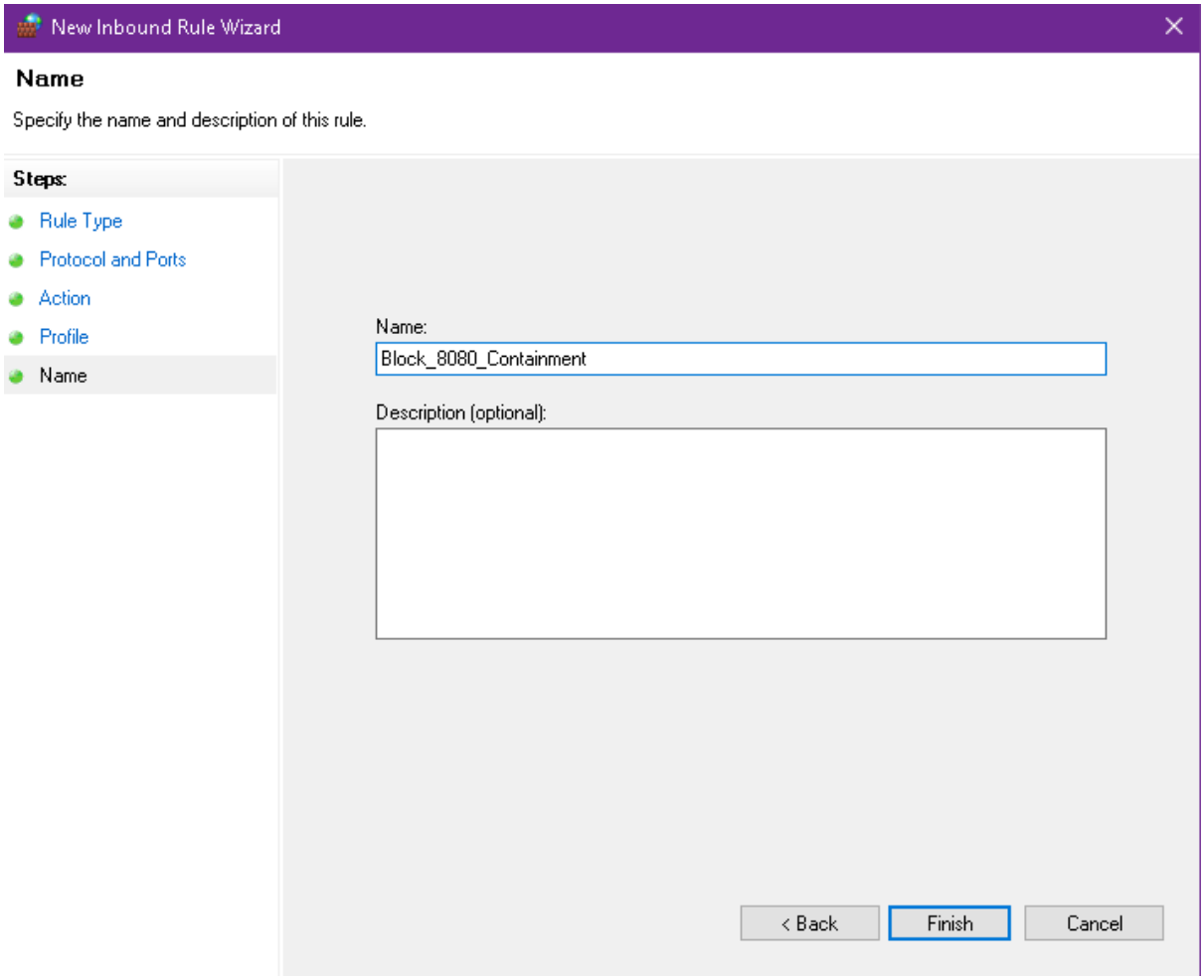



*Figure 35:Validating the rule of containment (Block8080Containment).*

Documents a clear, auditable rule name so the containment action can be reviewed and repeated. This supports accountability and reduces ambiguity during investigation.

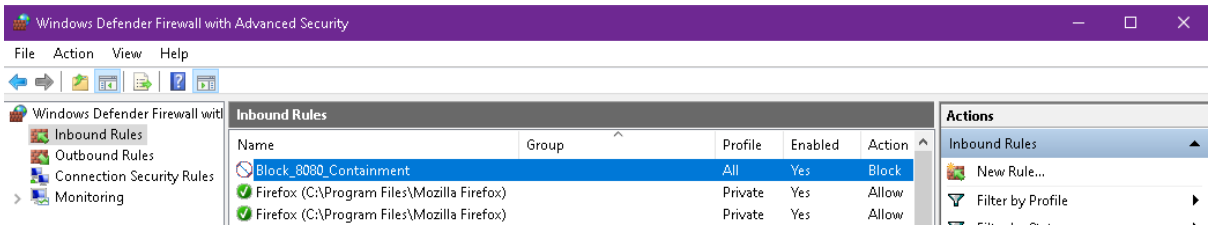



*Figure 36:Verifying it as an active rule seems to be an inbound block rule.*

Enables the rule of containment to be created successfully, needed to assert containment applied. This is the verification of controls screenshot.




*Figure 37:The implementation of the tcpdump command to capture network traffic to the vulnerable service port.*

Collects network data of the traffic between the attacker and the victim on a port of 8080 as a separate artefact. This is applicable in correlation with Wireshark, Sysmon and Security logs during investigation.

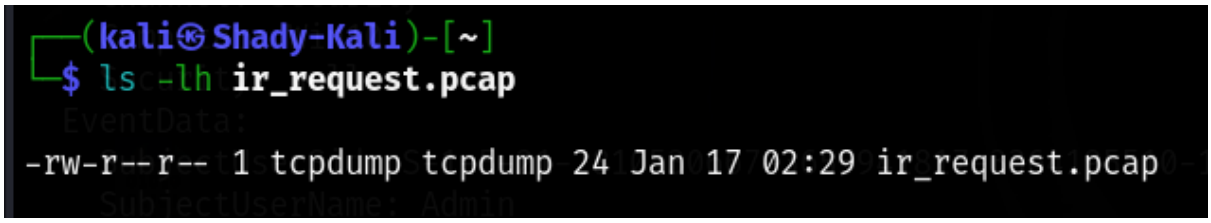



*Figure 38:Kali verifying the presence of irrequest.pcap through a file listing showing that the artefact of the capture was generated and it was not removed.*

Confirms the capture file exists and was retained, which is basic evidence handling and documentation. This prevents claims that the capture was not saved or was overwritten.




*Figure 39:Containment validation from attacker host: curl request to the victim HTTP service (192.168.72.141:8080) fails, confirming the vulnerable endpoint is no longer reachable (blocked or service stopped).*

Validates containment effectiveness by showing the attacker can no longer reach the victim service endpoint.

## 19. Cyber Playbook

This playbook is triggered when the request to an exposed service is an anomaly and endpoint data of process-creation evidence of RCE behaviour such as a service process spawning a command interpreter (e.g. powershell.exe or cmd.exe) is present. The incident is proven by triage which demonstrates: (1) input controlled by the attacker was received successfully into the exposed service, (2) a similar process was spawned with the correct command-line settings, and (3) host-based artefacts/logs confirm the behaviour of the execution. The scoping then confirms the identical service set-up and repetition patterns of triggers with the rest of the hosts within the identical time frame. Sequential containment is a technique to guarantee that there will be no further impact: again, isolate the host, which is already affected, block access to a vulnerable port/service, block suspect sources or patterns, and prevent losing valuable evidence. The extent of collecting evidence is limited and reproducible according to the production of EVTX logs, service and execution markers logs. The recovery is followed by remediation of the weakness (patching/hardening), the subsequent credentials reset, the absence of any persistence and the subsequent re-deployment of the service with extra attention are verified.

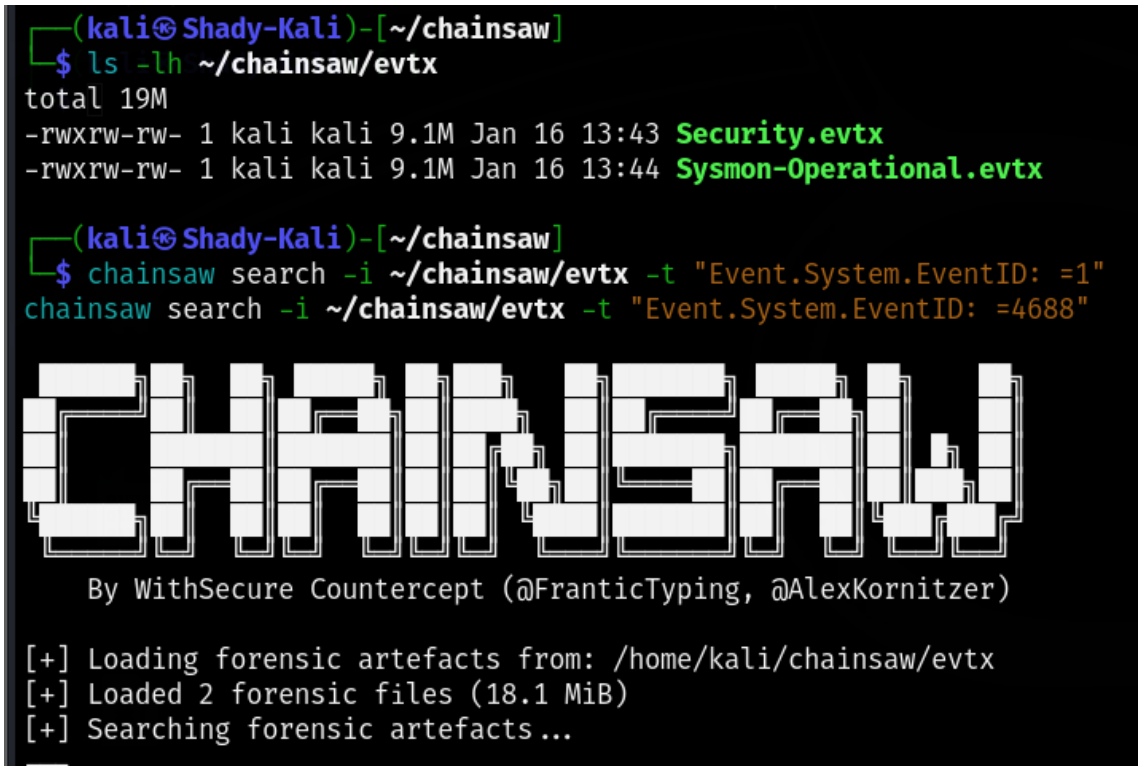



*Figure 40::(EVTX acquisition and offline triage on Kali): The logs accessed by Chainsaw indicate which Sysmon event ID 1 and Security event ID 4688 were represented by a*

*timestamp to relate to the execution time, exported by Windows via EVTX: Windows logs (security.evtx and Sysmon-Operation.evtx) and Chainsaw search query.*

Demonstrates of offline querying of acquired Windows event logs using automated queries. Facilitates quick detection and matching of events that are connected to executions without any reference being made to the live victim system.

```
C:\Windows\system32>
C:\Windows\system32>netstat -ano | findstr :8080
  TCP    0.0.0.0:8080           0.0.0.0:0              LISTENING       1240

C:\Windows\system32>_
```

*Figure 41:Victim-side validation using netstat showing TCP port 8080 in LISTENING state with an associated PID, confirming the exposed service is active and reachable (pre-containment baseline).*

Establishes the baseline that the vulnerable service is running and externally reachable prior to containment actions. This confirms the attack surface existed at the time of detection.

```
C:\Windows\system32>tasklist /FI "PID eq 1240"

Image Name                     PID Session Name        Session#    Mem Usage
========================= ======== ================ =========== ============
python.exe                    1240 Console                    1      3,920 K

C:\Windows\system32>wmic process where processid=1240 get Name,ProcessId,CommandLine /format:list


CommandLine=C:\Users\Admin\AppData\Local\Programs\Python\Python314\python.exe log4shell_sim_server.py
Name=python.exe
ProcessId=1240
```

*Figure 42:Process attribution on the victim using the tool tasklist and WMIC to map PID 1240 to python.exe and extract the entire command line (log4shellsim_server.py) to verify that this tool confirms the ownership of roles and services.*

Links the listening network service  to its owning process and command line. This facilitates the correct attribution of the attacked service that leads to the execution

n  behaviour.

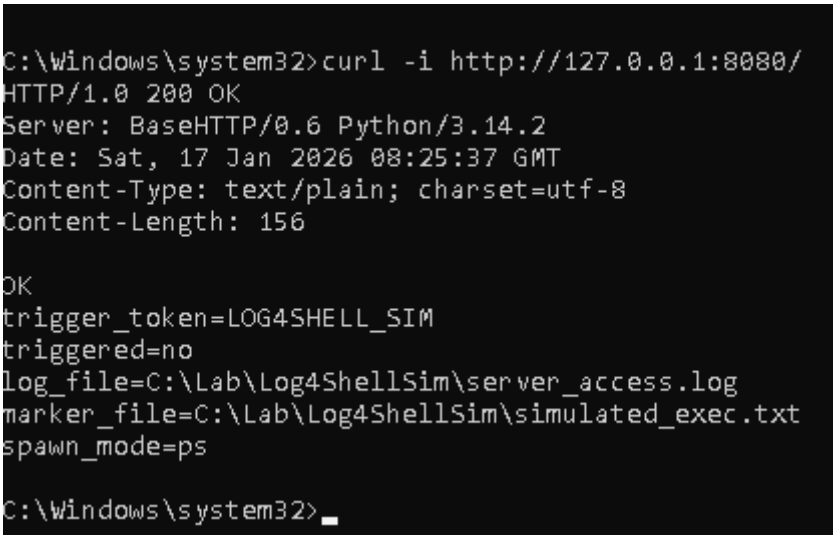



*Figure 43:Local baseline check of the victim that confirms the presence of the service on 127.0.0.1:8080 and responds to HTTP 200 OK and logs the log and marker files paths that they would use later to determine the presence of the execution.*

Ensures the service is still running locally and logs are present. This serves as a controlled baseline pre- and post-containment.

## 20. Prevention Action Plan

The main control is the timely management of vulnerability and dependency of internet facing services (Java components, in particular), with the help of secure configuration baseline and fast patching of critical RCE problems. Access to service ports should be restricted as well as possible (allowlisting) and the exposure of services made to internal systems should be segmented to minimize the spread of ransomware. The endpoint controls are recommended to harden the scripting and execution-pathways by using process-creation logging (command-line capture), observing high-risk parent-child links (service - PowerShell), and to control application-wide to lower ad hoc execution. The measures of resilience have a part to play in minimizing the operational impact in case an intrusion continues to take place, immutable/offline backups and tested restore procedures. Governance policies and controls strengthen least privilege on service accounts, separation of user and admin responsibilities, and the provision of clear log retention and incident management policies.

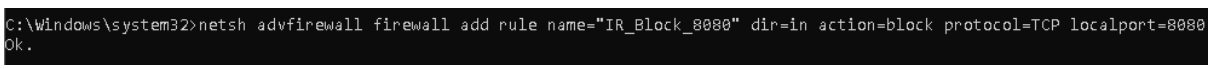


*Figure 44:Implementation of a preventive host-based control by creating a Windows firewall rule to block inbound TCP traffic on port 8080.*

This figure shows the implementation of a host-based preventive control by creating a Windows Firewall rule to block inbound TCP traffic on port 8080. It directly removes external exposure of the vulnerable service and serves as the primary mitigation action.




*Figure 45:Attend to the security relevant event logs mode with wevtutil export command with filenames that are date-stamped to provide support to retention and evidential integrity.*

This figure demonstrates the exporting of Windows Security and Sysmon Operational logs using native tooling, to keep evidence with the timestamp identified filenames. It sets the requirement for maintaining logs and evidentiary integrity for future forensic examination.

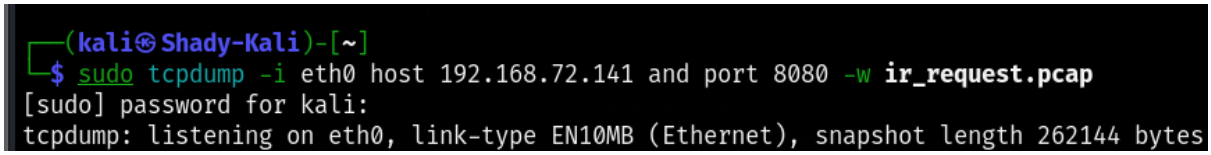



*Figure 46: Packet capture started to record details of communication at the port level.*

This illustration shows how to start a package capture from the attacker/observer node to monitor the network traffic directed to this unsecured service port. It allows evidence to be collected in the packet level for validation and forensic recovery.

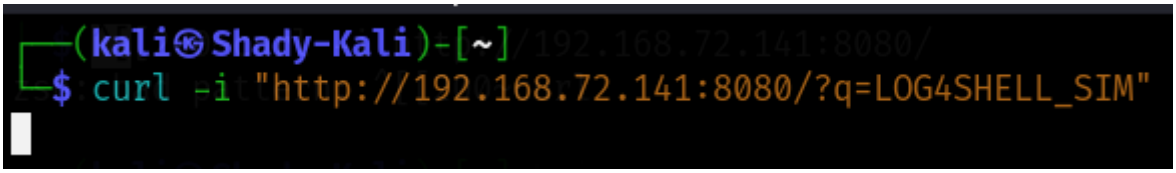



*Figure 47:External connectivity test from the attacker node to the victim service endpoint to validate reachability and control effectiveness.*

This figure validates whether the victim service remains reachable from an external host after preventive controls are applied. It directly tests the effectiveness of the firewall rule.

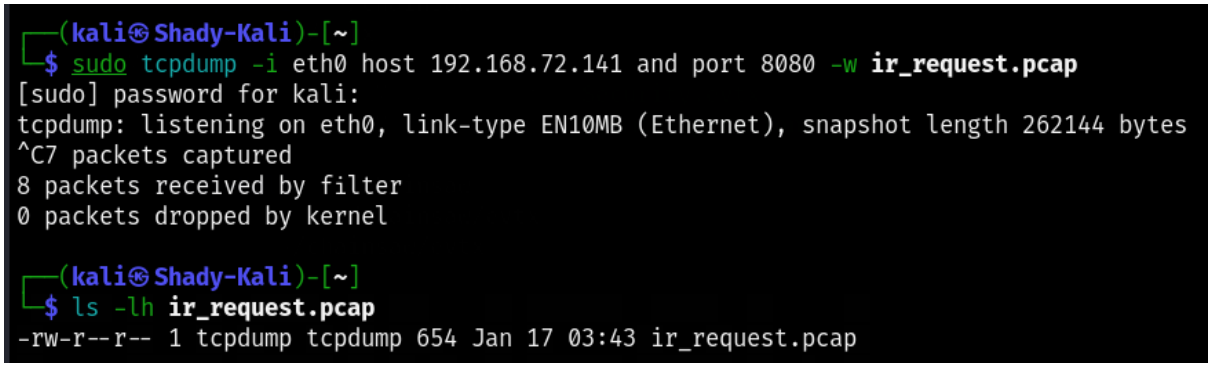



*Figure 48:Checking of the artificing of packet capture (ir request.pcap) evidences that network evidence had been recorded and maintained successfully.*

This figure verifies that the packet capture file was created successfully and saved, this is evidence that Network evidence gotten recorded during the test window.




*Figure 49:Successful extraction and export of triage results into structured output files, enabling reporting and appendix-ready evidence packaging.*

This figure shows the successful extraction of triage results into structured output files, enabling reporting, appendix inclusion, and evidence packaging.

## 21. Conclusion of Section B

This breach-and-attack simulation was behaviourally equivalent to Log4Shell-like open-door access and service-stylesheet execution without generating exploit payloads. Creatable artefacts in exposed service input created by the attacker were observed in Sysmon, Windows Security logs, service access logs and packet capture and allowed the test path of reconnaissance to execution and visible impact to be reconstructed. Findings Favor quick triage as well as justifiable reporting to stakeholders.

**Assumptions:** The target service was accessible, logging was active, timestamps were monotonous and the test window had no known administrative activity that would potentially allow service-induced command traffic.

**Limitations:** No exploitable Log4j component has been run; validation is not exploiting replication. Limited telemetry and lab scale as well as possible encryption minimize certainty in comparison to enterprise monitoring.

**Challenges:** It can be difficult to differentiate the attacker-like service activity and normal ones without baselining. Correlation is time sensitive; it contains time drift and missing events particularly to lineage of parent and child processes.

**Recommendation:** Patch governance of internet-facing services should be prioritised, exposure should be controlled by segmentation and least privilege, and logs should be centralized in a SIEM to correlate network and process events. Store evidence through exporting logs and hash artefacts.

**Further enhancement:** To enhance the visibility, add DNS/proxy/web logs or EDR and automate correlation with detection rules. Expand the situation with manipulated sideways movements and data-selection indicators and make the actions non-destructive.

# 22. References


1. Nir, S. M. (2022, November 28). How a Cyberattack Plunged a Long Island County Into the 1990s. The New York Times. https://www.nytimes.com/2022/11/28/nyregion/suffolk-county-cyber-attack.html
2. Jones, D. (2024, September 18). Suffolk County ransomware attack linked to lack of planning, ignored warnings. Cybersecurity Dive. https://www.cybersecuritydive.com/news/suffolk-county-ignored-threat-warnings/727352/
3. Julien Mousqueton. (2021). Group: alphv. Ransomware.live. https://www.ransomware.live/group/alphv
4. Phipps, A., & Nurse, J. R. C. (2025). Inside ransomware groups: An analysis of their origins, structures, and dynamics. Computers & Security, 160, 104705–104705. https://doi.org/10.1016/j.cose.2025.104705
5. #StopRansomware: ALPHV Blackcat | CISA. (2024, February 27). Cybersecurity and Infrastructure Security Agency CISA. https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-353a
6. BlackCat ransomware attacks not merely a byproduct of bad luck. (2022). Sophos. https://www.sophos.com/en-us/blog/blackcat-ransomware-attacks-not-merely-a-byproduct-of-bad-luck
7. Breaking Down the BlackCat Ransomware Operation. (2022, July 7). CIS. https://www.cisecurity.org/insights/blog/breaking-down-the-blackcat-ransomware-operation
8. BlackCat, Software S1068 | MITRE ATT&CK®. (2021). Mitre.org. https://attack.mitre.org/software/S1068/
9. IBM Security. (2023, May 30). BlackCat ransomware levels up stealth speed exfiltration. Ibm.com. https://www.ibm.com/think/x-force/blackcat-ransomware-levels-up-stealth-speed-exfiltration